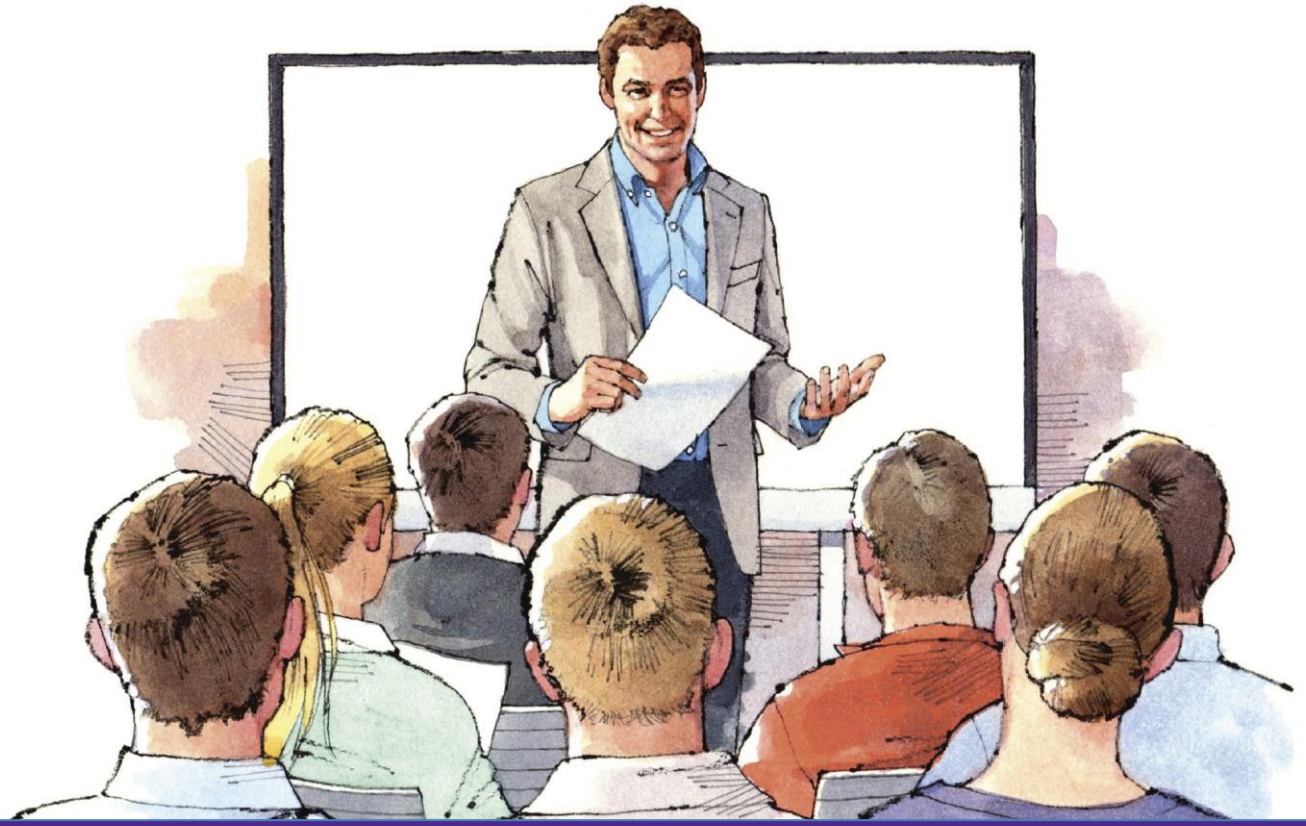
CQI | IRCA

CQI & IRCA

Certified Training

Welcome

Welcome to your CQI and IRCA Certified
ISO 22301
Lead Auditor
(Business Continuity Management Systems)



www.quality.org/training

Intertek has been independently assessed and approved by the CQI and IRCA. This means they have the processes and systems in place to deliver certified courses to the highest standard.

About the CQI and IRCA

The CQI is the only chartered professional body dedicated entirely to quality. IRCA is its specialist division dedicated to management system auditors.

The CQI leads the quality profession and is dedicated to promoting excellence through the key competencies of Governance, Assurance and Improvement.

We hope you enjoy your course

ISO 22301:2019 – SECURITY AND RESILIENCE

LEAD AUDITOR
CQI-IRCA
INTRO: GENERAL RULES, COURSE STRUCTURE, PROCESS AND METHODS OF ASSESSMENT

“By failing to prepare, you are preparing to fail”

Benjamin Franklin

“Continuity Plans are like backup parachutes – hardly ever needed but you don't want to operate without one”

DELEGATE INTRODUCTIONS

Please interview the delegate to your left so you may introduce them to the group.
Include the following information in the introduction:

- Their name
- A brief description of their organisation
- A brief job description
- Their involvement in Business Continuity Management
- A superpower you'd like to have

Time allowed – 2 minutes for Interview

1 minute for Introduction

COURSE LOGISTICS

- Start morning 9:30 AM
- 1 break (15 min.) during morning classes
- 1 lunch break (60 min.)
- 1 break (15 min.) during afternoon classes
- Monday-Thursday: classes till 16:00-30
- Friday: classes till 12 AM.
- Exam: 14:00-16:00 PM., Friday Sept 15th 2023

- **Questions posed & taken any time**
- **Respect colleagues' expertise, speak one at a time, listen well**
- **No multitasking**

BCP STATISTICS

- **9 in 10 small companies permanently close** if they are slow to reopen
- **100,000 small businesses in US were forced to close permanently** during COVID-19
- **51% of companies worldwide don’t have a business continuity plan 51 % от компаниите**
- **93% of companies without Disaster Recovery who suffer a major data disaster** are out of business within one year
- **54% of businesses said they had experienced a downtime incident** in the past five years that lasted at least eight hours
- **90% of smaller companies fail within a year** unless they can resume operations **within 5 days** after a disaster

https://invenioit.com/continuity/business-continuity-statistics/

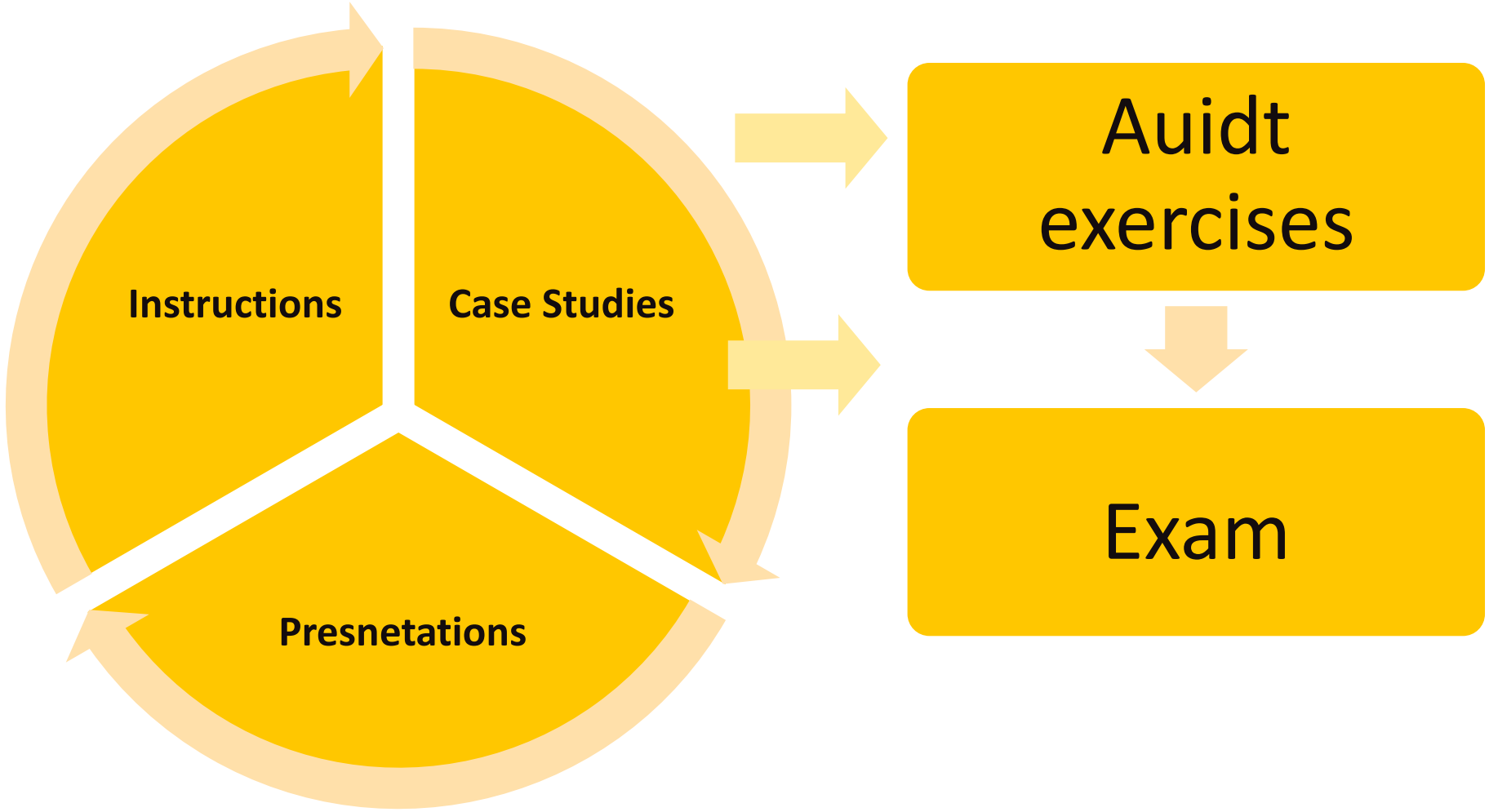
https://webinarcare.com/best-business-continuity-management-software/business-continuity-management-statistics/

COURSE STRUCTURE (1)

- Lectures and Discussions
- Exercises – to enforce and consolidate
- Security and resilience — Business continuity management systems — Requirements

BCMS = Business Continuity Management System
BCM = Business Continuity Management
BC = Business Continuity

STRUCTURE


Instructions
Case Studies
Presnetations
Auidt exercises
Exam

COURSE STRUCTURE (2)

- Planning, Conducting and Reporting Audits
- Audit Simulation Studies
- Role Play and Verbal Presentation

Take notes as you require to facilitate discussions!

COURSE STRUCTURE (3)

<u>Continuous Assessment</u>

Delegates will be assessed throughout the course for:

- Participation – Teamwork
- Application
- Contribution
- Comprehension
- Exercise and Teamwork Presentation
- Communication Skills
- Time Keeping and Attendance

A Pass Mark of 70% is required!

COURSE STRUCTURE (4)

Examination

- The course curriculum requires that an examination is taken on the last day of the course.
- A four (4) part examination is set by CQI-IRCA. The pass mark is 70% with a minimum of 50% to be passed in each section.

COURSE OBJECTIVES (1)

To provide delegates with the knowledge and skills required:

- to perform first, second- and third-party audits of BCMS processes
- against the requirements of ISO 22301:2019
- in accordance with ISO 19011:2018 Guidelines for auditing management systems;
- and ISO 17021:2015 Conformity assessment - Requirements for bodies providing audit and certification of management systems, as applicable.

COURSE OBJECTIVES (2)

Upon successful completion of this course you will:

- be able to prepare for, report on and carry out the follow up on BCMS (ISO 22301) Audit
- have undergone training recognised by the International Register of Certified Auditors (CQI-IRCA)
- have achieved the means to assess and improve your own BCMS

COURSE OBJECTIVES (3)

On completion of the course delegates will be able to:

- describe the purpose of a BCMS (ISO 22301:2019) including principles, processes and techniques used for management and assessment of a BCM system
- explain the scope and other criteria for BCMS Audits
- explain the purpose, content and interrelationship of ISO 22301:2019
- interpret ISO 22301:2019 requirements

COURSE OBJECTIVES (4)

- explain the role of a BCMS Auditor to plan, conduct, report and follow up a BCMS audit in accordance with ISO 19011:2018.
- explain and conduct Audits against ISO 22301:2019 requirements in compliance with ISO 19011:2018 and ISO 17021:2015, as applicable.
- prepare Audit reports with valid and factual non-conformities that add value.
- conduct follow up Audits that include evaluating effectiveness on corrective/preventive action.

COURSE OBJECTIVES (5)

- The CQI IRCA course learning objectives are listed in the introduction at the beginning of each section in your course manual;
- The course objectives and content are controlled by CQI IRCA. The course duration is at least 5 days (40 hours). 100% attendance is required;
- The learning objectives for each section are found on the first slide of each presentation.

DELEGATE RESPONSIBILITY

To qualify for certification delegates shall be required to:

- Demonstrate the ability to understand the BCMS (ISO 22301) requirements
- Attain the skills necessary to conduct effective audits against the ISO 22301:2019 clause requirements
- Maintain 100% attendance throughout the course
- Obtain an overall 70% continual assessment mark
- Obtain a min. 70% examination mark

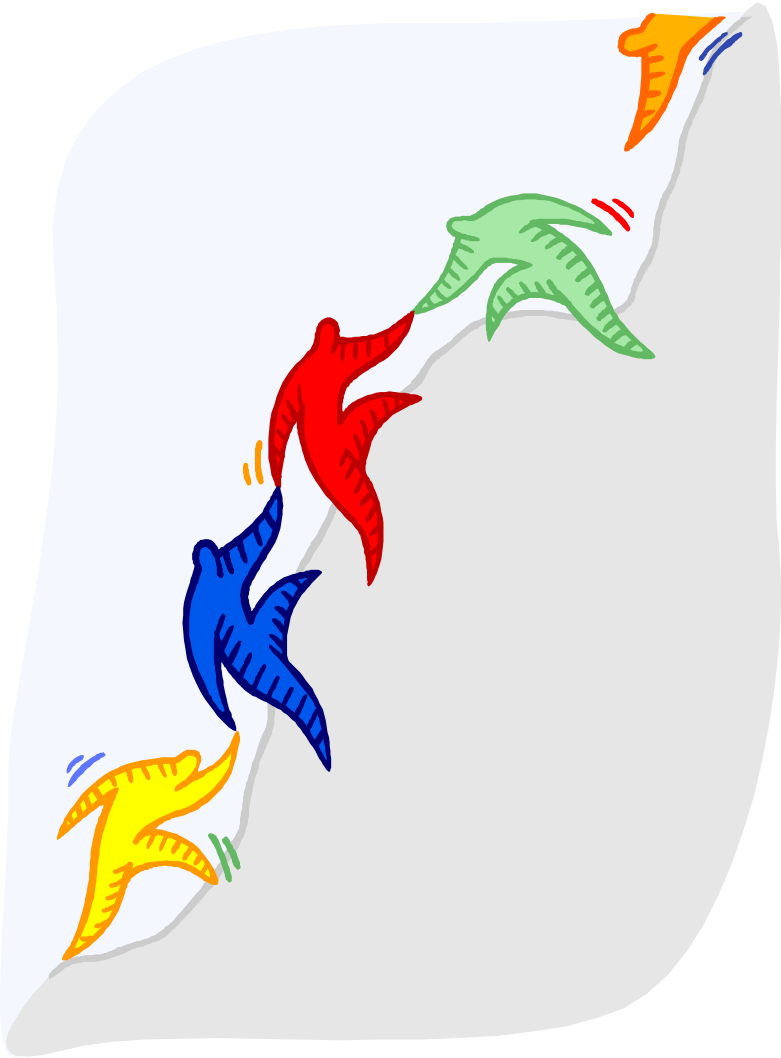
DELEGATE RESPONSIBILITY

The delegates are expected to have a prior knowledge of the:

- requirements of ISO 22301 and
- following BCM principles and concepts:
  - ✓ the purpose and benefits of a business impact analysis
  - ✓ the principles of risk management
  - ✓ typical business continuity strategies
  - ✓ business continuity response options
  - ✓ BCMS performance metrics, monitoring and performance measurement
  - ✓ exercise and testing methodologies

ACCELERATED LEARNING TECHNIQUES

- Auditing is an interactive and a team game
- We'll use a number of techniques to develop your auditing skills:
- Case studies, interviews, role games and the like
- We'd appreciate your active participation!



intertek

Total Quality. Assured.

SECTION 2 STANDARDS, PRINCIPLES AND DEFINITIONS

PURPOSE OF THIS SESSION: TO ENSURE THAT DELEGATES FROM DIFFERENT BACKGROUNDS, ARE ALL FAMILIAR WITH BASELINE BCMS (ISO 22301:2019) TERMINOLOGY. TO DISCUSS THE MAIN BCMS PRINCIPLES AND INTERRELATIONSHIPS OF THE APPLICABLE STANDARDS.

HISTORY OF ISO 22301

A standard approach to BCM has been suggested for decades

Continued operations at a predefined tolerable level in case of a business disruption (due to a disaster or an incident) are fundamental for any organization.

In 2003 the British Standards Institute (BSI) published the so called Publicly Available Specification (PAS) 56 – a pre-standard document used for consultation

Current definition of ISO 22301:2019

business continuity - capability of an organization to continue the delivery of products and services within acceptable time frames at predefined capacity during a disruption

INDUSTRIAL STANDARDS AND FRAMEWORKS RELATED TO BCP

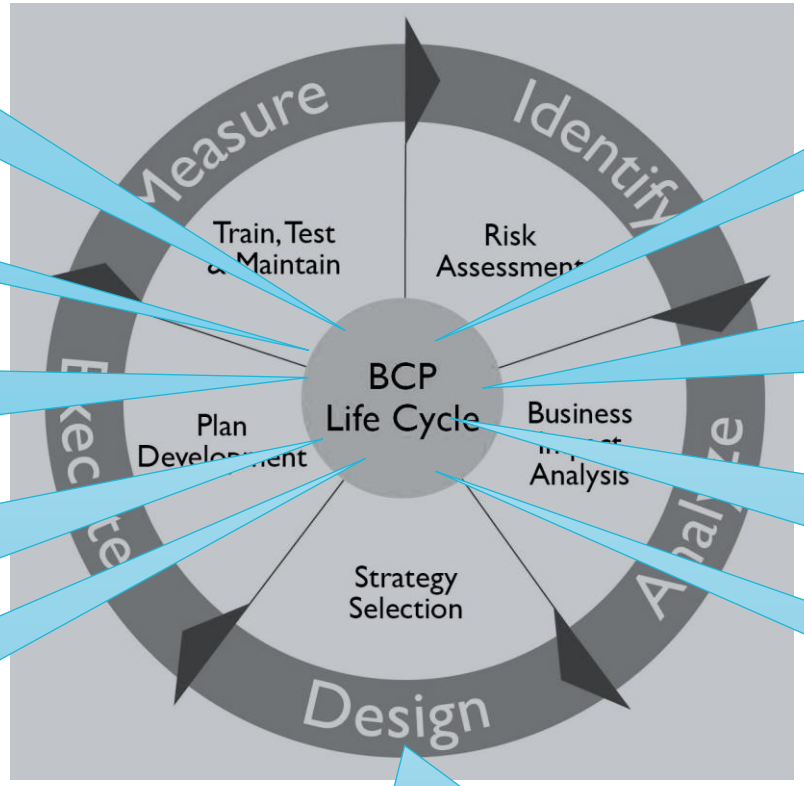
ISO 22301
BCM

BS 25999
BSI BCM, decommissioned after ISO 22301

ISO 9001
QMS in case BCM has been defined as part of the org processes

ISO 20000
IT Service Mgmt.

ISO 45001
Occupational Health and Safety



ISO 14001
Environmental Mgmt.

ISO 27001
IT Security Mgmt.

ISO 28000
Security Mgmt. for Supply Chain

COBIT 5
IT Audit Controls (ISACA)

ITIL
IT Infra Library (Axelos)

ISO 22301 AND THE PDCA APPROACH

- ISO 22301 applies the Plan (establish), Do (implement and operate), Check (monitor and review) and Act (maintain and improve) (PDCA) cycle to implement, maintain and continually improve the effectiveness of an organization's BCMS.
- This ensures a degree of consistency with other management systems standards, such as ISO 9001, ISO 14001, ISO/IEC 20000-1, ISO/IEC 27001 and ISO 28000, thereby supporting consistent and integrated implementation and operation with related management systems.

ISO 22301:2012 AND PDCA ACTIVITIES

Plan	Establish business continuity policy, objectives, targets, controls, processes and procedures relevant to analyzing business impact, managing risk and improving business continuity as necessary to deliver results in accordance with an organization's overall policies and objectives.
Do	Implement and operate the business continuity policy, controls and processes.
Check	Monitor and review performance against business continuity objectives and policy, report the results to management for review, and determine and authorize actions for remediation and improvement.
Act	Maintain and improve the BCMS by taking preventive and corrective actions, based on the results of management review and re-appraising the scope of the BCMS and business continuity policy and objectives.

HISTORY OF ISO 22301

- In 2006 BSI published **BS 25999-Part 1 Code of Practice**. In 2007 followed **BS 25999** Part 2: A Specification for BCM, intended for certification purposes.
- Most of the EU members adopted BS 25999
- USA, Canada, U.K. and Australia, developed their own national BCM standards
- The need for a single global standard became evident

HISTORY OF ISO 22301

- In 2007 the TC 223 of the International Organization for Standardization (ISO) released ISO PAS 22399-“Societal security — Guideline for incident preparedness and operational continuity”. ISO PAS 22399 appeared as an alternative of BS 25999.
- ISO 22301, introduced in 2010, superseded PAS 22399.
- In April 2012 was released - ISO 22301:2012 Societal security — Business continuity management systems — Requirements. (the first edition of the international standard)
- A second edition of ISO 22301 was published on 31st October 2019

THE ISO 22301:2019 STANDARD

- ISO 22301 provides the requirements for setting up and managing an effective Business Continuity Management System (BCMS)

- ISO 22301 inherited some of the best BCM practices established by the British Standard Institute and the Business Continuity Institute's Good Practice Guidelines (GPG) and ISO

THE STANDARD ISO 22301:2019

ISO 22301 is the first management standard that fully integrates ISO/Guide 83, "*High level structure and identical text for management system standards and common core management system terms and definitions*"

ISO 22301 addresses the problem of management of integrated systems and the interfaces between different management systems.

ISO 2230-: STANDARDS FAMILY

- **ISO 22300:2021** Security and resilience – Vocabulary
- **ISO 22313:2020** Security and resilience – Business continuity management systems – Guidance on the use of ISO 22301
- **ISO/TS 22317:2021** Security and resilience – Business continuity management systems – Guidelines for business impact analysis
- **ISO/TS 22318:2021** Security and resilience – Business continuity management systems – Guidelines for supply chain continuity
- **ISO/TS 22330:2018** Security and resilience – Business continuity management systems – Guidelines for people aspects on business continuity
- **ISO/TS 22331:2018** Security and resilience – Business continuity management systems – Guidelines for business continuity strategy
- **ISO/TS 22332:2021** Security and resilience – Business continuity management systems – Guidelines for developing business continuity plans and procedures
- **ISO/IEC/TS 17021-6:2015** Conformity assessment – Requirements for bodies providing audit and certification of management systems – Part 6: Competence requirements for auditing and certification of business continuity management systems

COMPLIANCE

This Standard provides a specification for use by internal and external parties, including certification bodies, to assess the organization's ability to meet regulatory, customer, and the organization's own requirements.

Being independently certified to the ISO 22301 provides assurance for interested parties that the organization is in compliance with BCM best practice.

BUSINESS BENEFITS OF BCMS

- Framework
- Resilience
- Reputation
- Competitive advantage
- Business improvement
- Continuous improvement
- Compliance
- Win more contracts
- Cost savings
- Delivery
- Capability for managing a disruption

BCMS KEY COMPONENTS (1)

- A policy
- People with defined responsibilities
- Management processes relating to:
- Policy
- Planning
- Implementation and operation
- Documentation providing auditable evidence; and
- Business continuity management processes relevant to the organization, e.g. **Business Impact Analysis (BIA), Business Continuity Plan Development, etc.**
- Performance assessment
- Management review and
- Improvement

BENEFITS OF DOCUMENTING BCMS (1) – “THE PAPER PLANE”

Boeing 747-400 weighs c.a 183 tons

“An airplane takes off not until its design’s documentation weight become more than the airplane weight”

Boeing 747 Chief Designer

BENEFITS OF DOCUMENTING BCMS (2)

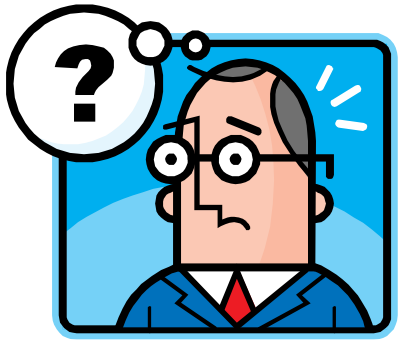
A reasonable set of documentation should be developed

The Standard specifies the necessary documented information:

- The scope, policies, objectives, risk assessments
- BIA
- BCM plans

PRACTICE

- Search the Internet and try to find a list of required documented information by ISO 22301
- Share the results with the rest of the team



BENEFITS OF DOCUMENTING BCMS (3)

BCMS documentation should be simple and usable, because:

- Often will be used at crisis & disaster situation
- Some disruptions and incidents to be managed by BCMS happen rarely

BCMS documentation should be available

BCM AND IDENTIFYING THREATS AND IMPACTS

It is important to use appropriate methods to identify potential risks, to assess impacts and to handle incidents:

- Risk and Business Impact Analysis
- ISO 27005 (Guidance on managing information security risks)
- Strategic SWOT analysis
- Operational Risk analysis
- BC & DR plans, etc.

intertek

Total Quality. Assured.

SECTION 3
OVERVIEW

PURPOSE OF THIS SESSION: TO MAKE AN OVERVIEW OF BCMS, IMPLEMENTATION STEPS, TO DESCRIBE THE BENEFITS OF IMPLEMENTATION AND CERTIFICATION OF
ISO 22301:2019

IMPLEMENTING ISO 22301:2019 (PDCA APPROACH)

- Establish the BCMS
- Implement and Operate the BCMS
- Monitor and Review the BCMS
- Maintain and Improve the BCMS

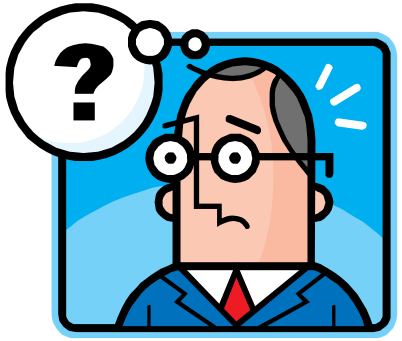
BCMS LIFECYCLE

	Mapping ISO 22301:2019	
1	Context of the organization	Clause 4 of ISO 22301:2012
2	Leadership	Clause 5 of ISO 22301:2012
3	Planning	Clause 6 of ISO 22301:2012
4	Support	Clause 7 of ISO 22301:2012
5	Operation	Clause 8 of ISO 22301:2012
6	Performance evaluation	Clause 9 of ISO 22301:2012
7	Improvement	Clause 10 of ISO 22301:2012

EXERCISE

Teams

- Prepare SWOT Analysis for:
- Team 1, 3, … Benefits of Implementation of BCMS
- Team 2, 4, … Benefits of Certification of BCMS
- Use a flipchart sheet
- You have 5 minutes



BCMS: BENEFITS OF IMPLEMENTATION

Strengths	Weaknesses
Opportunities	**Threats**

BCMS: BENEFITS OF CERTIFICATION

Strengths	Weaknesses
Opportunities	**Threats**

TOP SECTORS IN BCMS CERTIFICATION

- Finance and insurance
- Telecommunications
- Information Technology
- Production industries
- Energy Generation and Distribution

ISO Survey of certs/country/sector

intertek

Total Quality. Assured.

SECTION 4
ISO 22301:2019 STRUCTURE

PURPOSE OF THIS SESSION: TO DESCRIBE THE STRUCTURE OF ISO 22301:2019 AND AUDITING PERSPECTIVE

ISO 22301:2019 STRUCTURE

1 Scope

2 Normative references

3 Terms and definitions

4 Context of the organization

- Understanding of the organization and interested parties
- Scope
- BCMS

5 Leadership

- Leadership
- Leadership & commitment
- Policy
- Roles & responsibilities

6 Planning

- Risks and opportunities
- Business continuity objectives and plans
- Planning changes to the BCMS

ISO 22301:2019 STRUCTURE (2)

7 Support

- Resources & Competence
- Awareness & Communication.
- Documented information

8 Operation

- Ops Planning and control
- Business impact analysis (BIA) and risk assessment
- Business continuity strategy & solutions
- Business continuity plans and procedures

9 Performance evaluation

- Monitoring
- Internal audit
- Management review

10 Improvement

- Nonconformity and corrective action
- Continual improvement

GENERAL

The ISO 22301:2019 specifies the requirements for setting up and managing an effective BCMS

This emphasizes the importance of:

- understanding business continuity needs and the necessity for establishing policy and objectives for business continuity;
- implementing and operating controls and measures for managing an organization's overall business continuity risks;
- monitoring and reviewing the performance and effectiveness of the BCMS; and
- continual improvement based on objective measurement.

1. SCOPE

- ISO 22301:2019 specifies the requirements “This document specifies requirements to implement, maintain and improve a management system to protect against, reduce the likelihood of the occurrence of, prepare for, respond to and recover from disruptions when they arise.”.
- The requirements specified in ISO 22301:2019 are “*generic and intended to be applicable to all organizations… regardless of type, size and nature of the organization*”.
- The extent of application depends on the organization’s operating environment and complexity (and available resources).

AUDITING PERSPECTIVE

- ISO 22301:2019 must be used as a reference during auditing process.
- There are many “shall”-s in the standard’s clauses, hence – mandatory requirements. Relevant evidences & documents must be presented.
- Use “shall”-s requirements when preparing auditors check lists.

intertek

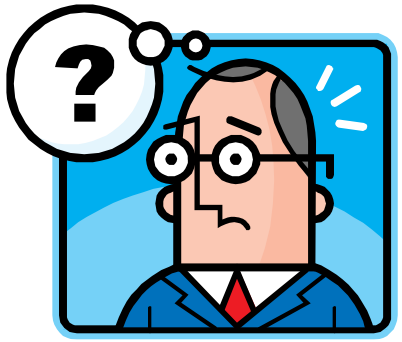
Total Quality. Assured.

SECTION 5
TERMS AND DEFINITIONS

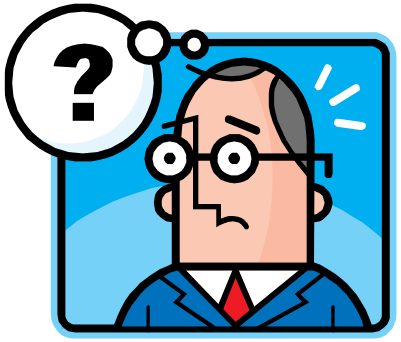
PURPOSE OF THIS SESSION: TO EXPLAIN THE KEY BCMS' TERMS AND DEFINITIONS RELATED TO ISO 22301:2019

QUIZZ

- BCMS specific terms and definitions
- The tutor will ask you questions about BCMS terms and definition, team by team
- Give short answers, referring to the ISO 22301 Clause 3
- Each correct answer will give 1 point to your team



GIVE DEFINITION FOR:



Q1. Activity

Q2. Audit

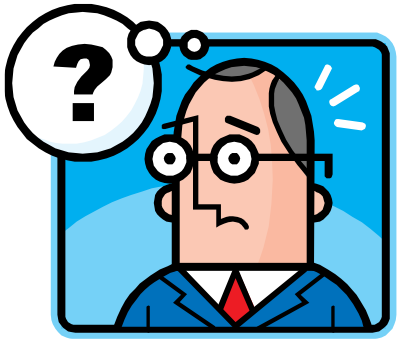
Q3. Business Continuity

Q4. Prioritized Activity

Q5. Risk

Q6. Management System (BCMS)

GIVE DEFINITION FOR:



Q7. Business Continuity Plan (BCP)

Q8. Business Impact Analysis (BIA)

Q9. Impact

Q10. Disruption

Q11. Incident

intertek

Total Quality. Assured.

SECTION 6
ISO 22301:2019 CONTEXT, LEADERSHIP & PLANNING

PURPOSE OF THIS SESSION: TO DESCRIBE THE ACTIVITIES RELATED TO CONTEXT, LEADERSHIP & PLANNING OF THE BCMS DEFINED IN ISO 22301:2019, TO DESCRIBE AND COMMENT THE OBLIGATORY “SHALL” REQUIREMENTS AND POSSIBLE LIMITATION/EXCLUSIONS

CONTEXT OF THE ORGANIZATION (1)

- The requirement of this clause is to have considered the ‘external and internal issues’, ‘interested parties’ and their requirements to ensure that the BCMS is relevant to the organization's activity and its stakeholders needs and expectations.

- The objectives and concerns of external stakeholders shall be considered when developing the BCMS.

- The term ‘issue’ covers problems and important matters related to the BCMS which need to be addressed.

CONTEXT OF THE ORGANIZATION (2)

The needs and expectations of interested parties have to be understood, and the BCMS of the organization has to be aligned with its interested parties' expectations in a balanced way.

CONTEXT OF THE ORGANIZATION (3)

Examples for interested parties:

- Organizations: the decision-makers within;
- Customers, end-users, etc.
- Suppliers, providers of a product/service/information;
- Certification/accreditation bodies or consultants;
- Regulatory bodies;
- Non-governmental organizations.

CONTEXT OF THE ORGANIZATION (4)

External context

external environment in which the organization seeks to achieve its objectives [ISO Guide 73:2009]

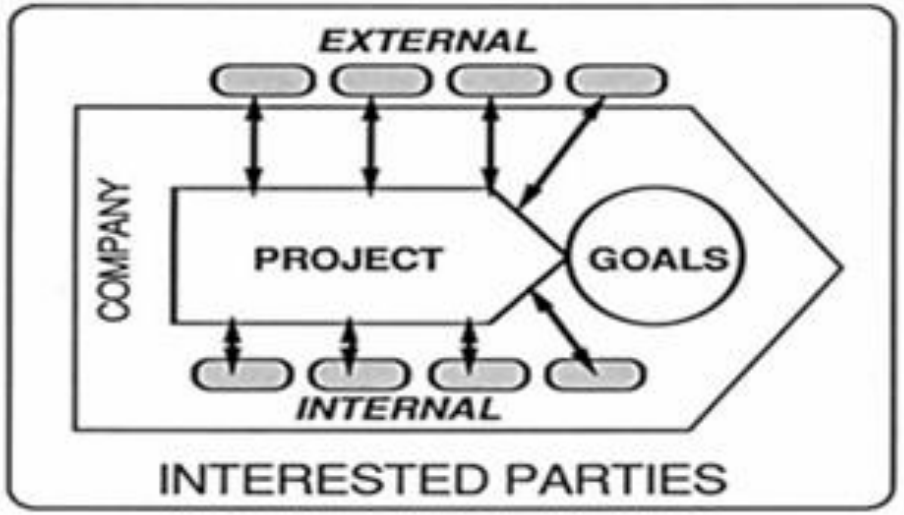
Internal context

internal environment in which the organization seeks to achieve its objectives. [ISO Guide 73:2009]

CONTEXT OF THE ORGANIZATION (5)

Example of processes that may be used for this purpose:

- Identification of the interested parties and their requirement’;
- Identification of internal and external issues/context;
- Assessment of internal and external environment /issues and of interested parties;
- Monitor and manage interested parties' relationships;
- Internal and external communication, etc.



UNDERSTANDING THE NEEDS AND EXPECTATIONS OF INTERESTED PARTIES

ISSUES WITH INTERESTED PARTIES

Sample Internal Interested Parties:

- Owners of the Company
- Top Management
- Line Functions, such as Marketing, Production, Maintenance, etc.
- Quality Assurance Organisation
- Safety Organisation
- Internal Personnel Groups
- Workers
- Representatives of Trade Unions
- Reference Groups
- Other Projects

Sample External Interested Parties:

- Authorities of various sections, like construction, social, import/export, taxation, work safety, labour, environment, etc.
- Financing sources like banks, stockholders, public finance, etc.
- The Press
- Politicians
- Trade unions
- Church
- Competitors
- Suppliers
- Cooperative Parties
- Families of the Personnel

Auditors to verify if the organization has followed following approach towards Context

Issues or Points of Conflict:

What are the situations in which the rights or obligations of the interested parties are in conflict?

Interested Parties:

Who other than those directly presented in the conflict have an interest?

Consequences of Action:

Identify those that have the highest probability of occurring or the greatest impact first

Consequences of Action:

What are the responsibilities of each individual to other interested parties?

Are these grounded in moral considerations or are they a rationalization?

CONTEXT OF THE ORGANIZATION (CONT.)

Practice Session:

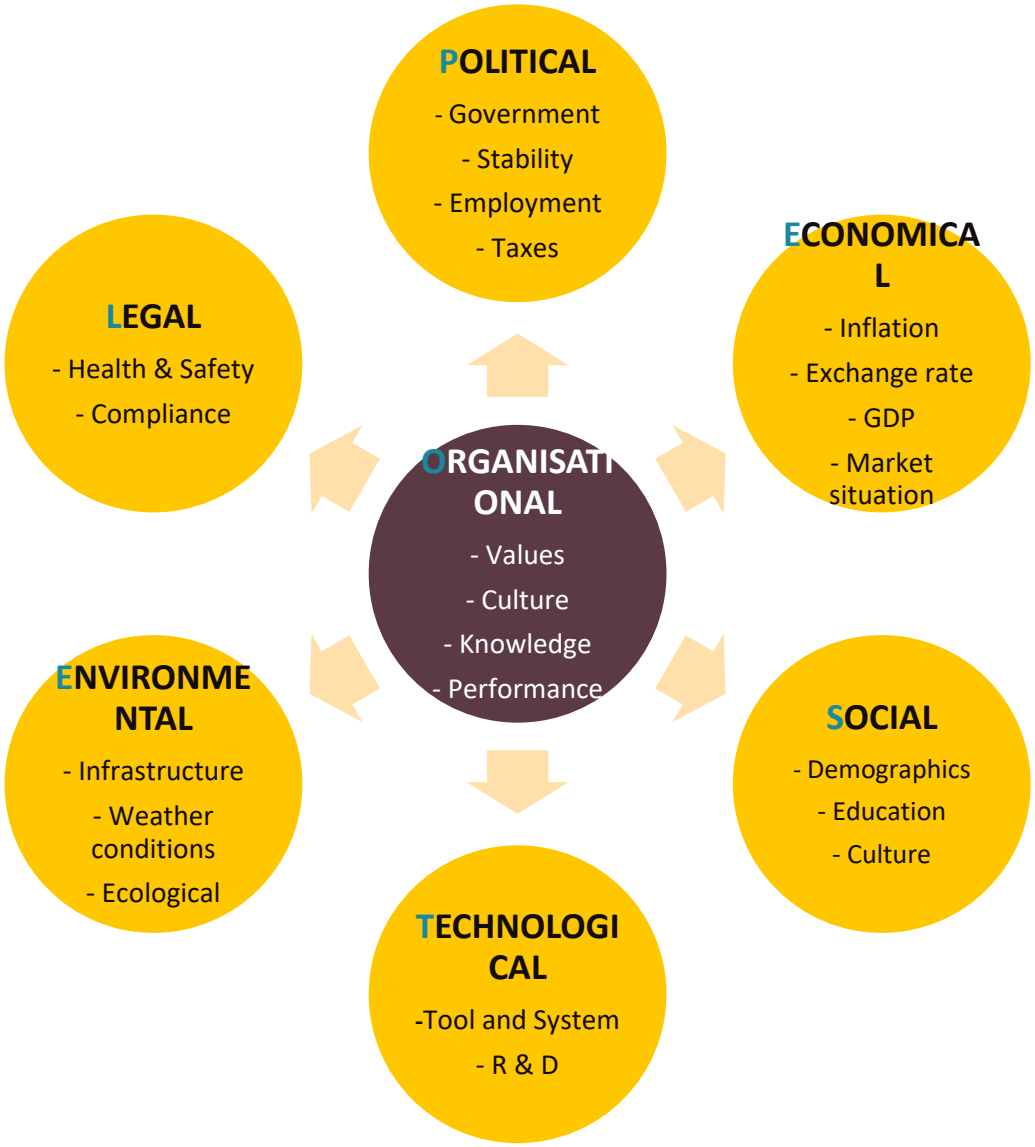
Work with your team and give example of audit evidence that auditors could gather and evaluate to determine conformity/nonconformity with this requirement

ISO 22301:2019 gives no practical approach to organizational context analysis

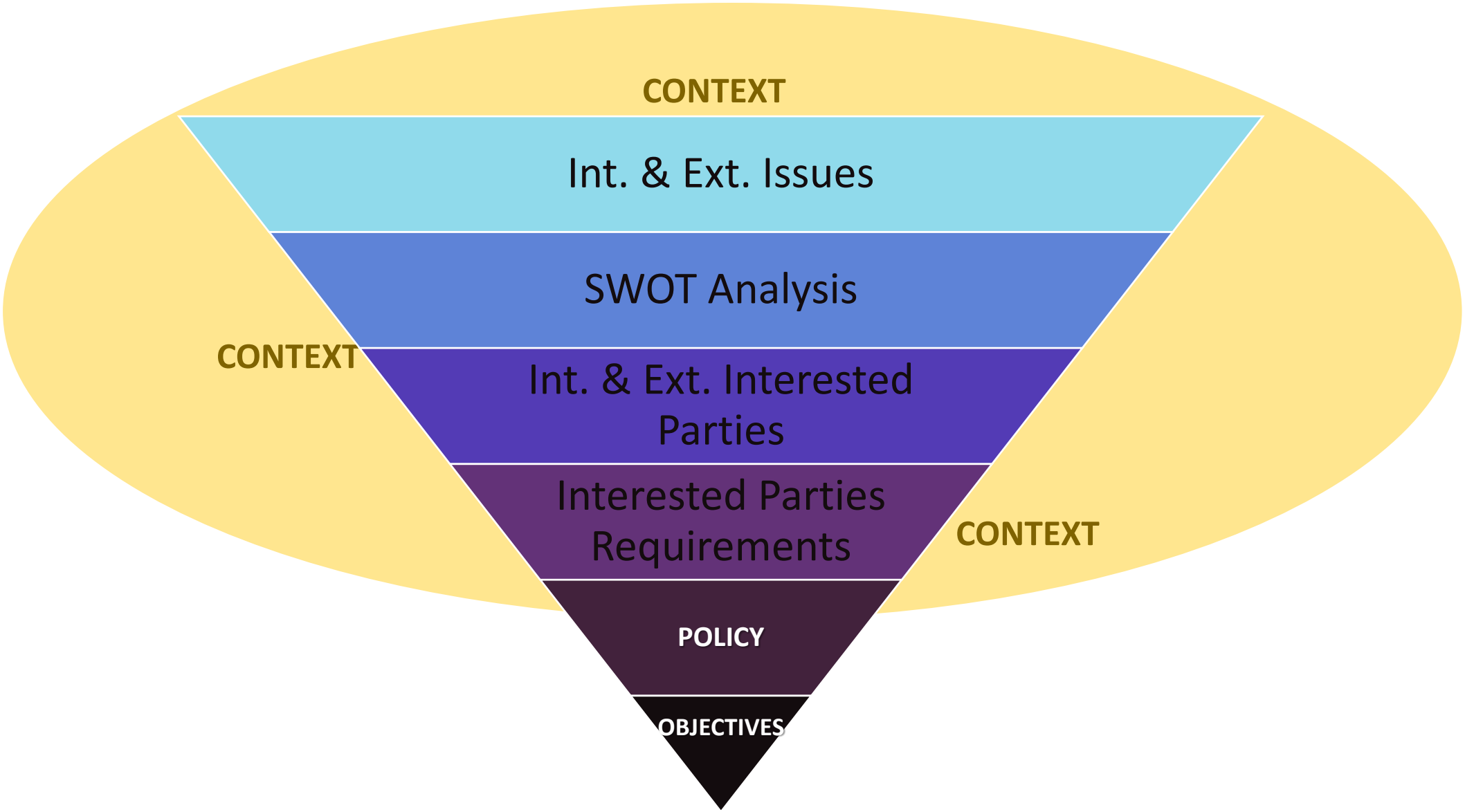
It’s not mandatory but any of the following methods could be deployed:

- SWOT analysis
- PEST or PESTLE analysis
- SOAR
- Porter’s Five Forces Analysis
- Value Chain Analysis, etc.

P E S T E L O METHOD FOR IDENTIFYING EXTERNAL & INTERNAL ISSUES



CONTEXT DEPENDENCIES



SCOPE

- The organization must determine and document the boundaries and the scope of the BCMS (Cl. 4.3.1).

- The boundaries and applicability of the BCMS should be communicated to the relevant internal and external parties.

- The organization shall document and explain exclusions if there are any. The exclusions shall not affect the organization’s ability to provide continuity of business and operations (Cl. 4.3.2).

SCOPE SAMPLES

CERTIFICATE

This is to certify that the Business Continuity Management System of

RADWARE LTD.

22, Raoul Wallenberg St. , Tel Aviv , Israel

Has been assessed and complies with the requirements of :

ISO 22301:2019

This Certificate is Applicable to

All business processes and information systems associated with and applied to Manufacturing, Delivery and Support of Radware On-prem and cloud products, solutions and services.

Initial Approval:	16/11/2021		
Certification Decision:	16/11/2021		
Valid Until:	16/11/2024	**Certificate No.:**	114392

CERTIFICATE

certifies that the Service Management System of

Disig, a.s.

Záhradnícka 151, 821 08 Bratislava
Slovak Republic

has been established and duly implemented and company applies it in accordance with the standard

ISO 22301:2019

provision for the following areas:
1. The provision of qualified reliable services and reliable services within the meaning of regulation of the European Parliament and of the Council n° 910/2014 and law n° 272/2016 Coll. as amended.

Certified locations: Záhradnícka 151, 821 08 Bratislava

On the basis of the certification audit, report I No. 1705/18-2 and surveillance audit, report No. 1705/20-5, it was proven that the management system meets the requirements of the standards stated above.

Certificate No.:	BC – 1705/20
Initial certification date:	08.02.2019
Date of issue:	11.11.2020
Expiry date:	07.02.2022

Standard

ISO/IEC 22301:2012

Scope of certification

THE BUSINESS CONTINUITY MANAGEMENT SYSTEM COVERS ALL THE BUSINESS PROCESSES AND INFORMATION SYSTEMS ASSOCIATED WITH AND APPLIES TO DESIGN, TRANSITIONS, IMPROVEMENT OF THE PROVISIONING OF CO-LOCATION SERVICES, MANAGED SERVICES, SECURITY SERVICES BY CTRLS THROUGH INFRASTRUCTURE AS A SERVICE (IAAS) MODEL INCLUDING PUBLIC, PRIVATE AND HYBRID CLOUD HOSTING, 4COPY CLOUD, VIRTUAL PRIVATE CLOUD, DISASTER RECOVERY SOLUTIONS, SAP/ERP SOLUTIONS, BACKUP AND RECOVERY SOLUTIONS, CRM AND CUSTOM APPLICATION HOSTING, NETWORK MANAGEMENT. THESE SERVICES ARE PROVIDED THROUGH OUR SERVERS LOCATED IN HYDERABAD (MADHAPUR & NANAKRAMGUDA), NAVI MUMBAI, BENGALURU AND NOIDA. IT ALSO INCLUDES SUPPORT SERVICES LIKE HR, PHYSICAL SECURITY, DC OPERATIONS/MAINTENANCE, PROCUREMENT, FINANCE, STORES AND INFRASTRUCTURE.

Original cycle start date:	**24 July 2013**
Expiry date of previous cycle:	**23 July 2019**
Recertification Audit date:	**04 May 2019**
Recertification cycle start date:	**24 July 2019**

Subject to the continued satisfactory operation of the organization's Management System, this certificate expires on: **23 July 2022**

Certificate No. **IND.20.35/BC/U** Version: **2** Revision date: **07 July 2020**

ASOK, I'M PUTTING YOU IN CHARGE OF PANDEMIC CONTINGENCY PLANNING.
Dilbert.com DilbertCartoonist@gmail.com
CALCULATE THE IMPACT ON OUR BUSINESS IF 50% OF OUR EMPLOYEES ARE UNABLE TO BE PRODUCTIVE.
10-24-09 ©2009 Scott Adams, Inc./Dist. by UFS, Inc.
THAT'S TWICE AS GOOD AS WE'RE DOING NOW.
JUST MAKE SOME SLIDES THAT SAY IT WOULD BE BAD.

BCMS

The organization shall:

Establish, implement, maintain and continually improve the BCMS, including the processes needed and their interactions in accordance with the requirement of this international standard (Cl. 4.4)

LEADERSHIP

LEADERSHIP

- The top management of the organization shall demonstrate leadership and commitment with respect to the BCMS (Cl. 5.1).
- Policies and objectives established for the BCMS should be compatible with the strategic direction of the organization.
- The BCMS requirements should be integrated into the organization’s business processes.
- The top management should provide adequate resources for the business continuity management system and for continual improvement (Cl.5.2).

COMMITMENT (1)

Top management *shall* provide evidence of its commitment to the BCMS by

- establishing a business continuity policy,
- ensuring that BCMS objectives and plans are established,
- establishing roles, responsibilities, and competencies for BCM,
- integrating of the BCMS requirements into the organization's business processes
- appointing roles and responsibilities with appropriate authority and competencies for the implementation and maintenance of the BCMS (Cl.5.3).

COMMITMENT (2)

Top management *shall* ensure that

- criteria for accepting risks and the acceptable levels of risk are defined ,
- internal audits and management reviews of the BCMS are conducted.

Top management *shall*

- engage in exercising and testing of the BCMS,
- demonstrate its commitment to continual improvement.

WHEN AUDITING MANAGEMENT COMMITMENT

BCMS is crucial for business survival!

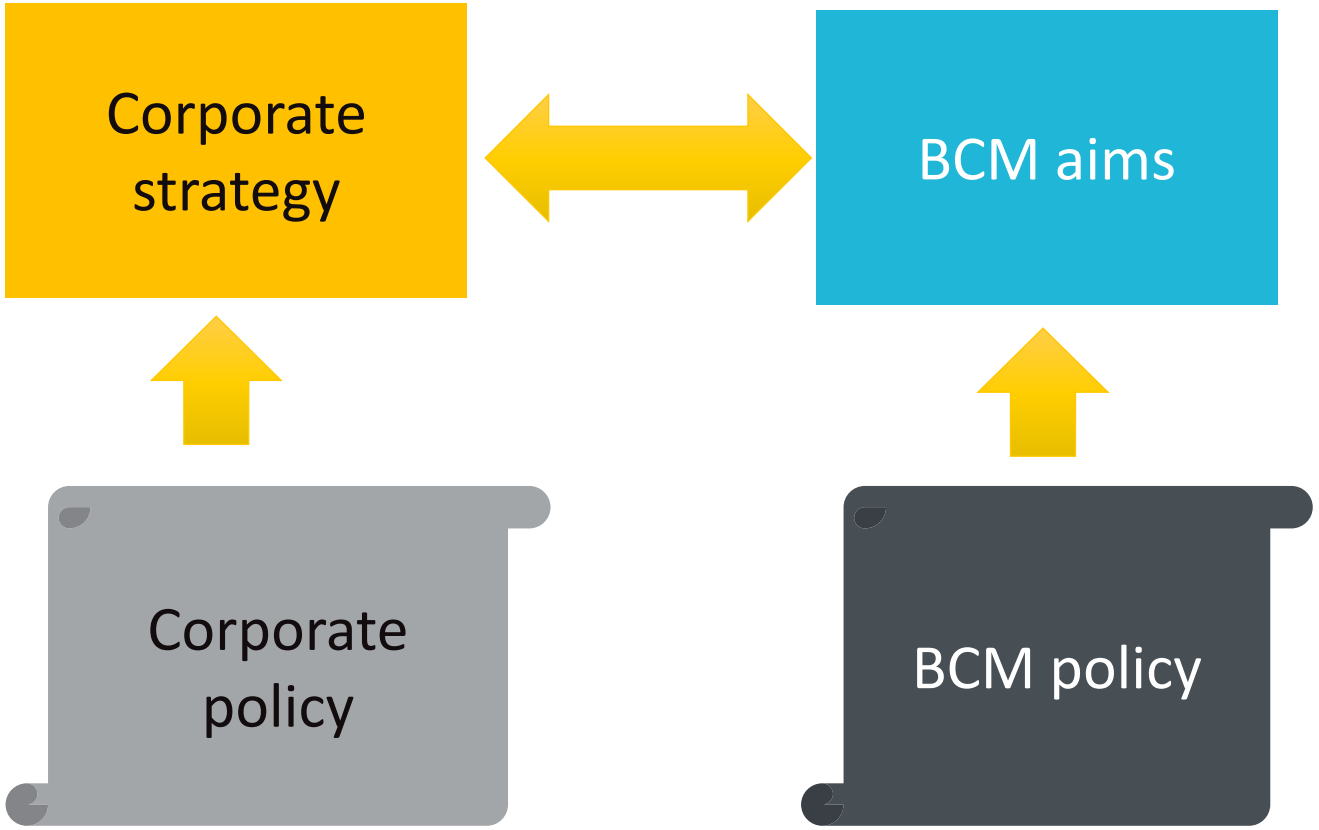
Focus on testing leadership commitment to the BCMS:

- Has management demonstrated leadership?
  - ✓ Setting strategic BCMS goals
  - ✓ Maintaining the change
  - ✓ Working with people (but not commanding)

- Is BCMS fully integrated into organizations business processes and culture?
- And Clause 5.2 requirements understand & met?

WHEN AUDITING MANAGEMENT COMMITMENT

Look for Strategic aligning of BCMS to Business



POLICY

- Top management *shall* establish a business continuity policy that is appropriate to the purpose of the organization and provides a framework for setting business continuity objectives.

- The BCMS policy *shall* include a commitment to satisfy applicable requirements and for continual improvement of the BCMS.

- The BCMS policy *shall* be documented, communicated within the organization, and made available to interested parties.

Examples of BCM policy

ROLES & RESPONSIBILITIES

Top management *shall* assign the responsibility and authority for

- ensuring that the BCMS is established and implemented in accordance with the requirements of ISO 22301:2019;
- reporting on the performance of the BCMS to top management (Cl. 5.3).

Examples of BCM program management

Ways to document/audit R&R

- RACI (Responsible, Accountable, Consulted, Informed)
- Org chart
- JD (Job descriptions)
- Dedicated document/s on R&R in BCMS

Levels of R&R:

- **BCMS level roles:**
  - Program manager BCMS
  - Functions representative
  - Exec leadership
  - Sponsor
  - Risk assessor, risk owners, asset owners
  - Business Response Management Team rep (BRMT)
  - General biz functions (real estate, facilities, security, HR, finance)...
- **Biz process level:**
  - Process owner
  - Ops resources
  - Team manager

PLANNING

PLANNING THE BCMS (1)

When planning for the BCMS, the organization has to determine the risks and opportunities that need to be addressed to

- ensure the management system can achieve its intended outcome(s),
- prevent, or reduce, undesired effects,
- achieve continual improvement (Cl. 6.1).

The organization shall plan how to integrate and implement into its BCMS processes the actions needed

- to address these risks and opportunities (Cl. 8.1),
- evaluate the effectiveness of these actions (Cl. 9.1).

PLANNING THE BCMS (2)

When planning for the BCMS, the organization must also determine

- the relevant external and internal issues that affect the intended outcome of the BCMS (Cl.4.1),
- the needs and expectations of interested parties that are relevant to the BCMS (Cl. 4.2.1),
- legal and regulatory requirements (Cl. 4.2.2).

THE BCM COULD BE UNITED EFFORTS GAME

Implementing BCM could be expensive and require a lot of resources

When auditing put an effort on searching for opportunities to improve based on BCM partnership e.g.:

- Joint disaster recovery sites
- Cross-backup along the supply chain
- National/Local Agencies
- Public Private Partnerships
- Local businesses and the like

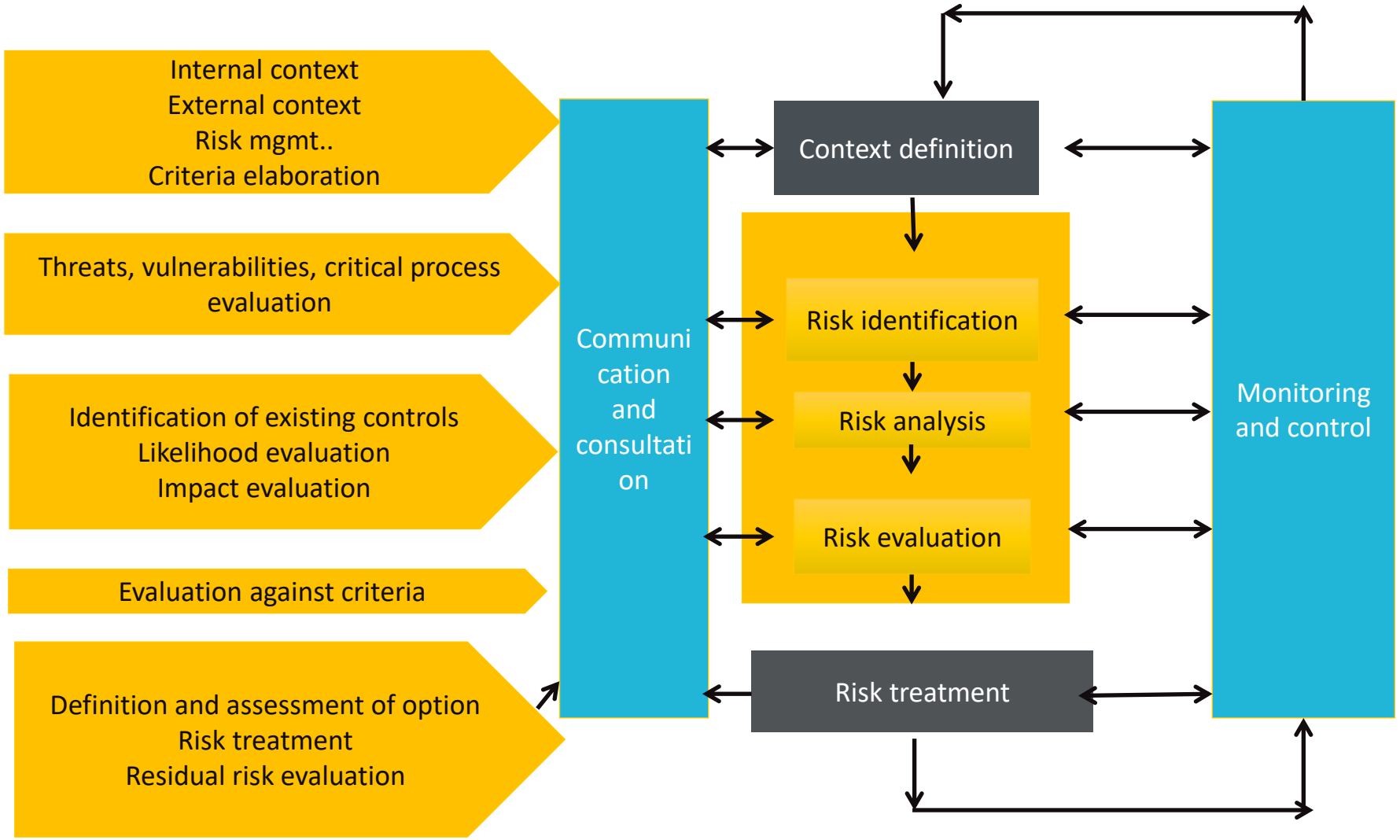
RISK MANAGEMENT

- Risk Management needs to be **embedded** as “second nature” of organization.

- Planning is not a single event, but an ongoing process, anticipating changes in the circumstances and continually determining risks and opportunities for the BCMS.

- **ISO 31000** – best practice guidelines to support effective management, it addresses the need to evaluate **risks consistently** and thus use the magnitude of a risk to prioritize actions

RISK MANAGEMNT IN BCMS (BASED ON ISO 31000)



AUDITING RISKS & OPPORTUNITIES

CHECK following in Audit of Risk Assessment

- All risks in relations of all Interested Parties in business considered in Risk Assessment – impacting products or services;
- Risk Evaluation Criteria is suitable to nature of business;
- Probability and Severity is part of Risk Evaluation Criteria;
- The scenarios of probability and severity are considered (Probability Changing or Impact Changes due to implementing of Controls to bring down the risk);
- Residual Risks are approved by process owners / authority;
- Risk Assessments are validated w.r.t Incidents (NC's, Complaints etc.)

- Design Failure Risk
- Product Failure Risk
- Process Failure Risk
- IT Failure Risk
- Environmental Risk
- Health & Safety Risk
- IT Security Risk
- Business Continuity Risk
- Resource Shortage Risk
- Natural Calamity Risk
- Other Risks

Risk level = Probability x Severity/Impact

Likelihood			
Very likely	Acceptable risk Medium 2	Unacceptable risk High 3	Unacceptable risk Extreme 5
Likely	Acceptable risk Low 1	Acceptable risk Medium 2	Unacceptable risk High 3
Unlikely	Acceptable risk Low 1	Acceptable risk Low 1	Acceptable risk Medium 2
What is the chance it will happen?	Minor	Moderate	Major

Impact
How serious is the risk?

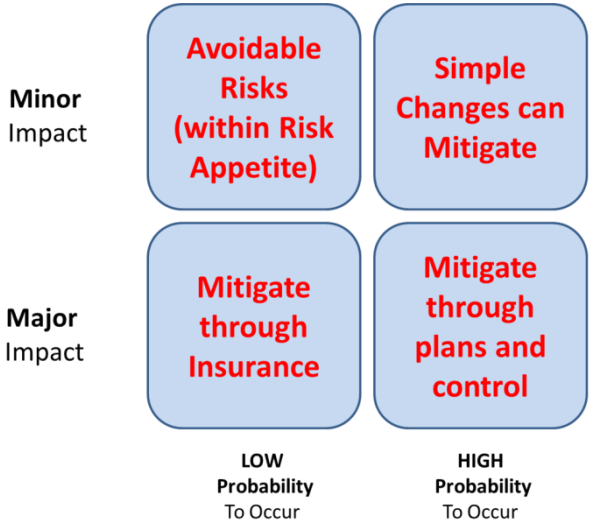
AUDITING RISK TREATMENTS IN RISK ASSESSMENTS

Risk Mitigation – Sequence in Selection:

Practically in normal life, you use the same sequence in treating any risk.

1. Avoid
   - If this is not possible, then:
2. Treat
   - If this is not possible, then:
3. Accept
   - If this is not possible, then:
4. Transfer

First step should be to "Avoid ", which is rare in most of the cases, rather than straight go for the "Treat"



RISK MANAGEMENT RESOURCES

- Personnel, skills, experience and competencies
- Resources distribution is each phase of the risk management process
- Techniques, methods and tools of the organization used for risk management
- Documented processes and procedures
- Knowledge and information management systems
- Training and development programs

DAY 2 START

“Whining session”/Parking lots – 5 min

“Life After Death by PowerPoint”: video by Don McMillan – 10 min

Documentation examples – 20 min:

- ISO survey
- BCP as part of QMS/QMS setup
- Functional roles/governance
- Policy
- Relationship between Incm and Crisis in HP
- External-internal issues
- Needs-expectations
- Change processes: following the respective section

Homework review – 15 min

SIPOC (PROCESS MODELLING APPROACH)

Process Step No	Supplier	Input	Process	Output	Customer
Step 1	Grocery	Cash Recipe Shopping list	Put shoes on, go to baba Genka's store	Bagfull of products (cheese, egss, sheets fo dough)	Me/wife
Step 2					
Step 3					
Step 4					

BUSINESS CONTINUITY OBJECTIVES AND PLANS

Cl. 6.2 Business continuity objectives shall be established and communicated within the organization. The business continuity objectives shall be

- consistent with the business continuity policy and measurable,
- aligned with the applicable requirements,
- documented, monitored and updated.

BUSINESS CONTINUITY OBJECTIVES AND PLANS (2)

To achieve its business continuity objectives, the organization shall determine

- who will be responsible,
- what will be done,
- what resources will be required,
- when it will be completed, and
- how the results will be evaluated (Cl.6.2).

BCMS OBJECTIVES EXAMPLES

Strategic: for the whole BCMS

Tactical:

- Related to Recovery Time Objectives (RTOs)
- Testing and training goals/objectives

Directions:

- Minimize loss in case of disruptions
- Ensure continuity of business in case of disasters
- Increase levels of safety for employees
- Improve risk managemnet strategies within the organization
- Increase customer satisfaction and improve

EXAMPLES

Achieve ISO 22301 cert by Dec 31st, 2023, in order to comply with legislation XYZ...”

Comply with demand of X number of clients with XXX $TCV in the next 12 months through achievement of ISO 22301 certification.

Improve the recovery time following incidents with 12 hours within the FY without significant expenses

PLANNING OF CHANGES

Changes to the BCMS shall be executed in a planned way

The org shall consider:

- Objective of changes and their consequences
- Integrity of BCMS
- Resources availability
- Distribution/re- of responsibilities and authorities

Examples of change processes

RESOURCES

CL. 7 SUPPORT – RESOURCES, COMPETENCY & AWARENESS

- Resources needed for the establishment, implementation, maintenance and continual improvement of the BCMS shall be determined and provided.
- BCM roles, responsibilities, competencies and authorities shall be defined and documented.
- Training is to be provided for the personnel with assigned BCM roles and responsibilities. Records of education, training, and qualifications are to be maintained.
- The personnel shall be aware of the business continuity policy, their contribution to the effectiveness of the BCMS, the implications of not conforming with the BCMS requirements, their role during disruptions
- **(Cl. 7.2&7.3).**

NB: differing form ISO 20000, which speaks about 4 types of resources (human, financial, technical, informational), ISO 22301 mentions “resources” only

Example of resources calculation

COMMUNICATION

The organization shall determine the internal and external communications relevant to the BCMS, including:

a) on what it will communicate;
b) when to communicate;
c) with whom to communicate;
d) how to communicate;
e) who will communicate.

DOCUMENTATION (1)

The BCMS shall include

- documented information required by the Standard,
- documented information determined by the organization as being necessary for the effectiveness of the BCMS.

The extent of documented information for a BCMS can differ from one organization to another due to

- the size of organization and its type of processes, products and services,
- the complexity of processes and their interactions,

The documented information may be in the form of policies, procedures, plans, risk assessment reports, work instructions, etc.

DOCUMENTATION (2)

The BCMS documentation shall have

- appropriate identification (e.g. a title, date, author or reference number),
- format (e.g. language, software version, graphics),
- media (e.g. paper, electronic).

Documented information shall be controlled to ensure that it is available and suitable for use, where and when it is needed, it is adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

DOCUMENTATION (3)

The organization shall control the

- distribution, access, retrieval and use,
- storage and version control,
- retention, disposition, use,
- prevention of the unintended use of obsolete information, and
- identification of documented information of external origin.

The organization shall ensure that there is adequate protection for the documented information (e.g. protection against improper use, unauthorized modification or deletion) (Cl. 7.5.3).

ISO 22031 DOCUMENTATION

Documented information:

- Legal requirements 4.2.2
- Scope and exceptions 4.3
- Policy 5.2
- Objectives and plans to achieve them 6.2
- Competences 7.2
- BIA and risks assessment 8.2?
- BCM Strategies and solutions 8.3
- BCPS and procedures, records of actions in disruptions, communications with parties 8.4
- Testing schedules and results 8.5
- Monitoring, measurement, analysis and evaluation mechanisms/data 9.1
- Internal audit procedures and plans/records 9.2
- Management review 9.2
- Non-conformity and corrective actions 10.1

Additional documented information for an effective BCMS:

- Client contracts and SLAs
- Results of BIAs
- Results of risk assessments
- Definition and selections of strategies for BCM
- General incidents response documentation
- Awareness program
- Communications related to both BCMS and incidents
- Training program for the org and individuals
- Contracts and SLAs with suppliers
- Plan related to BCP and risk assessments of suppliers
- Supplier comms procedures
- Post-incident reports and analysis
- Records of documentation review within the BCMS

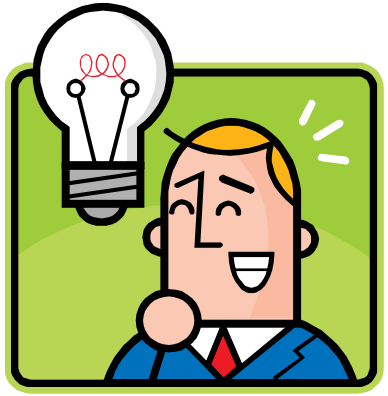
intertek

Total Quality. Assured.

SECTION 7
ISO 22301:2019
OPERATION

PURPOSE OF THIS SESSION: TO DESCRIBE CLAUSE 8 OF ISO 22301:2019, TO EXPLAIN OPERATIONAL PLANNING AND CONTROL, BUSINESS IMPACT ANALYSIS & RISK ASSESSMENT, BUSINESS CONTINUITY STRATEGIES, & SOLUTIONS, BC PLANS AND PROCEDURES; EXERCISE PROGRAM

THE CORE IDEA OF BCM!



To identify the critical activities and resources needed to support production and delivery of key products and services, understand the threats to them and choose appropriate risk treatment and controls.

OPERATION

The Operation (implementing and operating BCMS) covers:

- Operational planning and control (Cl. 8.1)
- Business impact analysis and risk assessment (Cl. 8.2)
- Business continuity strategies and solutions(Cl. 8.3)
- Business continuity plans and procedures (Cl. 8.4)
- Exercise Program (Cl. 8.5)

OPERATIONAL PLANNING AND CONTROL CL. 8.1

The organization shall:

- address the risks and opportunities determined in Cl.6.1,
- meet requirements and implement the control in accordance with the establishing criteria,
- keep documented information as evidence for the implemented activities,
- control planned changes and review the consequences of unintended changes, take action to mitigate adverse effects
- The organization shall ensure that outsourced processes and the supply chain are controlled. (Cl.8.1).

CL. 8.2 BIA AND RISK ASSESSMENT

Cl. 8.2.2 The organization shall use the process for analysing business impacts to determine business continuity priorities and requirements. The process shall:

a) define the impact types and criteria relevant to the organization’s context;

b) identify the activities that support the provision of products and services;

c) use the impact types and criteria for assessing the impacts over time resulting from the disruption of these activities;

d) identify the time frame within which the impacts of not resuming activities would become unacceptable to the organization;

NOTE 1 This time frame can be referred to as the "maximum tolerable period of disruption (MTPD)".

e) set prioritized time frames within the time identified in d) for resuming disrupted activities at a specified minimum acceptable capacity;

NOTE 2 This time frame can be referred to as the "recovery time objective (RTO)".

f) use this analysis to identify prioritized activities;

g) determine which resources are needed to support prioritized activities;

h) determine the dependencies, including partners and suppliers, and interdependencies of prioritized activities.

CL. 8.2.2 RISK ASSESSMENT

The organization shall implement and maintain a risk assessment process.

NOTE The process for risk assessment is addressed in ISO 31000.

The organization shall:

a) identify the risks of disruption to the organization’s prioritized activities and to their required

resources;

b) analyse and evaluate the identified risks;

c) determine which risks require treatment.

BIA AND RISK – ASSESSMENT OF COMPONENTS AND DEPENDENCIES

KEY QUESTIONS ON KEY ASPECTS OF BUSINESS

PEOPLE	ASSETS	PROCESSES	SUPPLIERS	PROFILE
Personnel: What staff do you need to perform critical functions?	**Buildings:** What locations the org delivers from?	**IT:** What IT assets are needed?	**Agreements:** Arrangements or agreements with other organizations?	**Reputation:** Key stakeholders?
Skills, expertise , trainings: What skills& expertise do you need to perform critical functions?	**Facilities:** What is needed for key functions?	**Documentation:** Key documents you need available?	**Suppliers and Contractors:** Do you procure services/products form suppliers and what are they?	**Legal considerations:** What key legal requirements?
Minimum levels of availability of employees: What is the minimum level of staff you need for a process/service?	**Equipment, resources:** What equipment you need for critical functions?	**Systems and Communications:** What systems and comms flows you need for your critical functions?	**Prioritization of Suppliers:** What are the critical ones?	**Vulnerable groups:** Who will be impacted of the org business stops and cannot perform critical functions?

BIA AND RISK ASSESSMENT

Impact can be qualitative or quantitative:

- Loss of key personnel
- Loss of physical assets
- Loss of information/data
- Service interruption
- Violation of legal requirements and financial sanctions
- Reputational damage
- Financial loss or revenue loss
- Loss of clients, suppliers, partners (external interested parties)
- Environmental, health and safety damage

Impact	Risk treatment effort		
Significant • Financial loss > 5 million • Loss of trust/reputation > 18 месеца • Loss of life • Significant or numerous penalties or legal actions • Complete IT outage with loss of critical data • Inability to hire or retain key personnel	Considerable actions needed to address risks	Risks need to be managed and monitored	Very high effort on risk mgmt.
Moderate (medium) • Financial loss < 5 million • Loss of trust/reputation 6-18 месеца • Injuries of one or several people • Isolated incidents of penalty, fraud, legal actions • IT outage during critical period • Difficulty to hire or retain key personnel	Risks can be accepted and monitored	Effort shall be made to manage risks	Risk mgmt. is necessary
Low (insignificant) • Financial loss < 500k • Loss of trust/reputation < 6 месеца • Isolated injuries • Civil actions or criminal activities threats • Intermittent IT interruptions during non-critical periods	Risks are accepted	Risks can be accepted and monitored	Risk treatment and monitoring
	Low > 36 months	**Medium** 18-36 months	**High** 12-18 months
	Likelihood		

EXAMPLE OF BIA AND RISK – ASSESSMENT

Risk identification		Analysis and assessment of risk					Risk control			
No	Risk	Probability (explanation)	Probability rating (1-6)	Impact (explanation)	Impact rating (1-6)	Risk level (probability x impact)	Treatment choice (Mitigation, transfer, acceptance, etc.)	Strength of control (1-6)	Residual risk(1-6)	Short description of risk treatment plan
1	Fire									
2	Earthquake									
3	Flood									
4	Loss of access									
5	Loss of power									
6	Loss of comms provider									
7	IT outage									
8	Strike									

5 STEPS' RISK ASSESSMENT (1)

Step 1: preparation of risk list and systematic approach to their assessment

Key product or service is scope of the BCMS	Supporting activities	Threat to supporting activities to cause disruption	Risk
Product/service № 1	Supporting activity № 1.1	Threat № 1.1.1	Risk № 1.1.1
		Threat № 1.1.2 ...	Risk № 1.1.2
	Supporting activity № 1.2	Threat № 1.2.1	Risk № 1.2.1
		Threat № 1.2.2	
		...	...
Product/service № 2	Supporting activity № 2.1	Threat № 2.1.1	Risk № 2.1.1

5 STEPS' RISK ASSESSMENT (2)

Step 2

Identify key products/services

Populate in column 1

Step 3

Identify supporting activities

Populate in column 2

Step 4

Identify threats and risks

Step 5

Asses risk level according to the matrix on the right

Impact

	Low	Medium	High
High	3	6	9
Medium	2	4	6
Low	1	2	3

Probability

Risk is graded through 2 parameters
Risk level = Probability x Impact

RISK ASSESSMENT MATRIX

PROBABILITY						
	0.9	**Very high 71-90%**	**0.045**	**0.09**	**0.18**	**0.36**	**0.72**
	0.7	High 51-70%	0.035	0.07	0.14	0.28	0.56
	0.5	Medium 31-50%	0.025	0.05	0.10	0.20	0.40
	0.3	Low 11-30%	0.015	0.03	0.06	0.12	0.24
	0.1	Very low up to 10%	0.005	0.01	0.02	0.04	0.08
			Very low	Low	Medium	High	Very high
			0.05	0.1	0.2	0.4	0.8
	IMPACT						

Impact and probability matrix

Categorization of the values of rating of identified risk

Probability scale

Probability rating in %

Impact rating

Subjectively chosen – less than 1

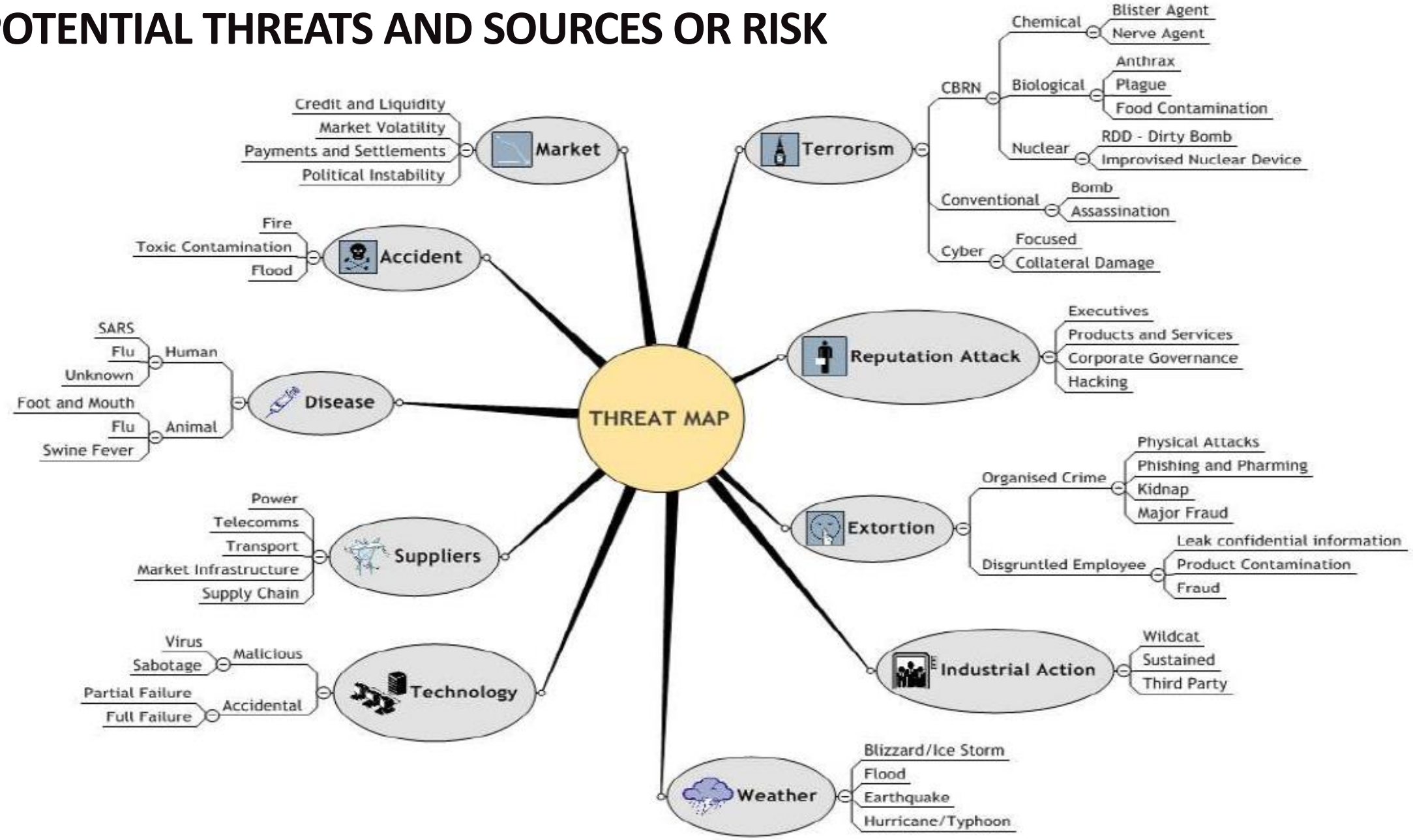
Qualitative rating

- Values above 0.18 – high priority
- Values around and above 0.05 – medium priority
- Values under 0.05 – low priority

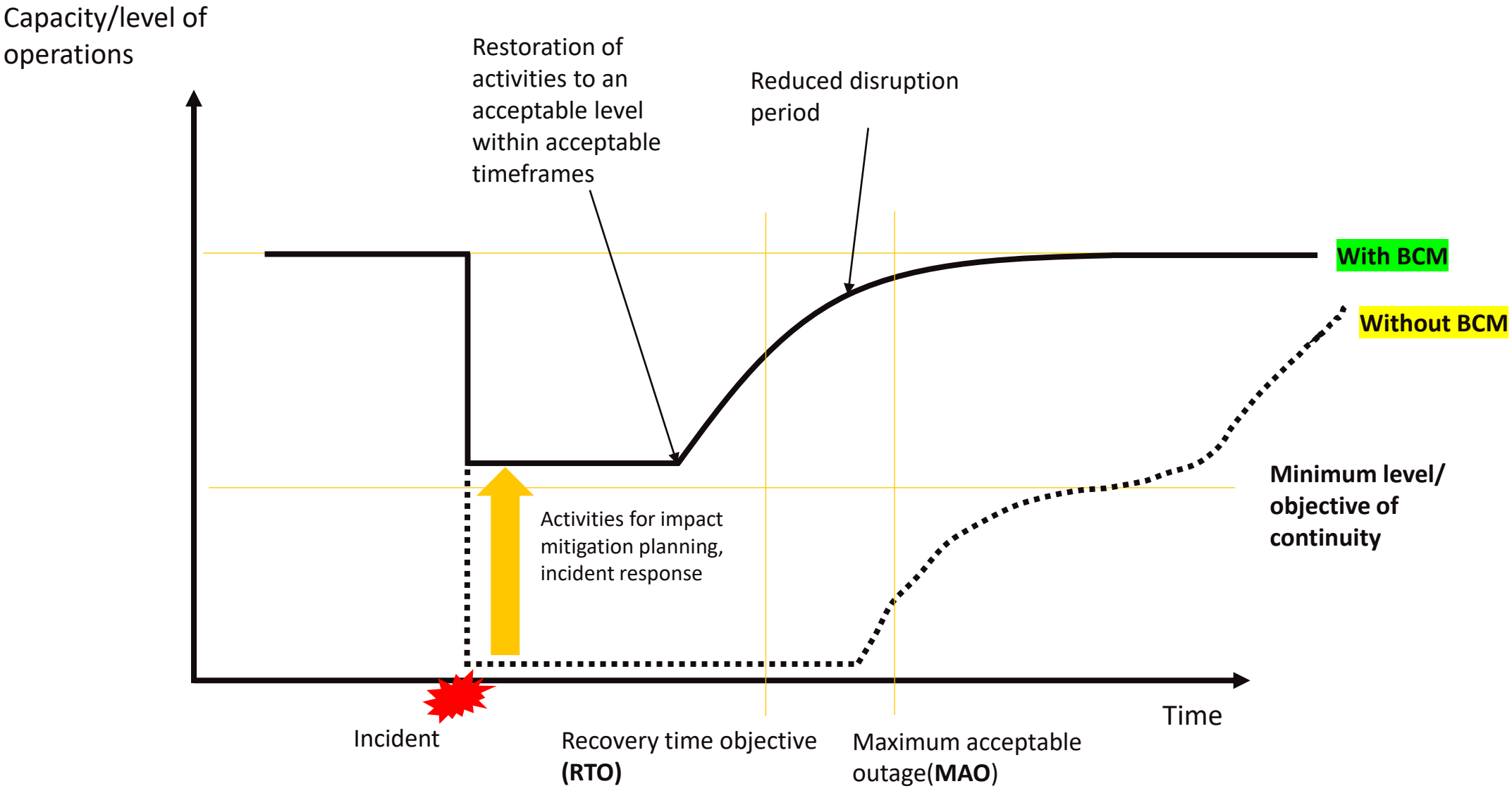
Line of Risk Tolerance

- Acceptable risks – below the line
- Unacceptable risks – above the line

POTENTIAL THREATS AND SOURCES OR RISK



HOW BCM WORKS IN TIMES OF DISRUPTIVE EVENTS – METRICS, EXAMPLE 1



KEY INDICATORS AND EQUASIONS

Key KPIs to check during audit

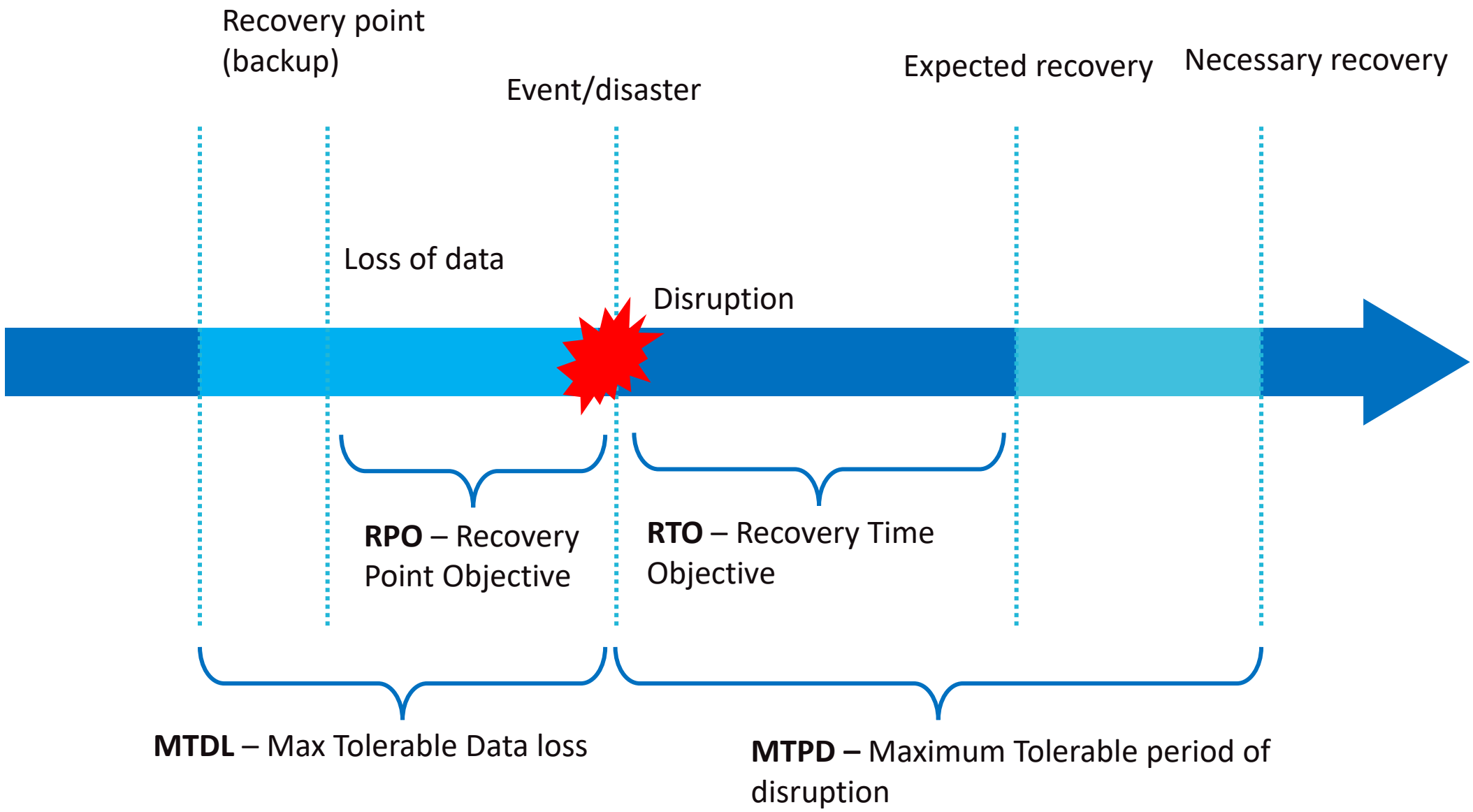
Business decision needed

KPIs	
MAO – Maximum Acceptable Outage	Time it would take for adverse impacts, which might arise as a result of not providing a product/service or performing an activity, to become unacceptable
MTPD	Maximum Tolerable period of disruption
RTO	Recovery Time Objective
RPO	Recovery Point Objective – determined by the time frame and volume of data that needs to be recovered
MTDL	Maximum Tolerable Data loss– how long and org can keep on operating without data/processes
PT	Prioritized Timeframes
MBCO – Minimum Business Continuity Objective	Time it would take for adverse impacts, which might arise as a result of not providing a product/service or performing an activity, to become unacceptable

RTO < MTPD
RPO < MTDL

Are these correctly planned?
Have they been met in times of testing/incidents?

HOW METRICS WORK – EXAMPLE 2



CL. 8.3 BUSINESS CONTINUITY STRATEGIES AND SOLUTIONS

8.3.1 General

Based on the outputs from the business impact analysis and risk assessment, the organization shall identify and select business continuity strategies that consider options for before, during and after disruption.

BUSINESS CONTINUITY STRATEGIES: EXAMPLES

Strategy	Description
Work from home	Employees work from home using remote connectivity tools and infrastructure
Relocation	Relocating employees to alternate locations and resuming operations from there
Transfer/ Split work	Training of resources within the organization who can undertake given activities
Work from office	When employees can't leave the office
Transfer to 3rd parties	Third parties with similar obligations may take over some of the activities in times of crisis

CL. 8.3 BUSINESS CONTINUITY STRATEGIES AND SOLUTIONS

8.3.2 Identification of strategies and solutions

Identification shall be based on the extent to which strategies and solutions:

a) meet the requirements to continue and recover prioritized activities within the identified time frames and agreed capacity;

b) protect the organization’s prioritized activities;

c) reduce the likelihood of disruption;

d) shorten the period of disruption;

e) limit the impact of disruption on the organization’s products and services;

f) provide for the availability of adequate resources.

CL. 8.3 BUSINESS CONTINUITY STRATEGIES AND SOLUTIONS

8.3.3 Selection of strategies and solutions

Selection shall be based on the extent to which strategies and solutions:

a) meet the requirements to continue and recover prioritized activities within the identified time frames and agreed capacity;
b) consider the amount and type of risk the organization may or may not take
c) consider associated costs and benefits.

RESOURCE REQUIREMENTS

8.3.4 Resource requirements

The organization shall determine the resource requirements to implement the selected business continuity solutions. The types of resources considered shall include, but not be limited to:

a) people;

b) information and data;

c) physical infrastructure such as buildings, workplaces or other facilities and associated utilities;

d) equipment and consumables;

e) information and communication technology (ICT) systems;

f) transportation and logistics;

g) finance;

h) partners and suppliers

CL. 8.3 BUSINESS CONTINUITY STRATEGIES AND SOLUTIONS

8.3.5 Implementation of solutions

The organization shall implement and maintain selected business continuity solutions so they can be activated when needed.

8.4 BUSINESS CONTINUITY PLANS AND PROCEDURES

8.4.1 General

The organization shall implement and maintain a response structure that will enable timely warning and communication to relevant interested parties. It shall provide plans and procedures to manage the organization during a disruption. The plans and procedures shall be used when required to activate business continuity solutions.

The organization shall identify and document business continuity plans and procedures based on the output of the selected strategies and solutions.

8.4 BUSINESS CONTINUITY PLANS AND PROCEDURES

Continued

The BC procedures shall:

a) be specific regarding the immediate steps that are to be taken during a disruption;

b) be flexible to respond to the changing internal and external conditions of a disruption;

c) focus on the impact of incidents that potentially lead to disruption;

d) be effective in minimizing the impact through the implementation of appropriate solutions;

e) assign roles and responsibilities for tasks within them.

8.4.2 RESPONSE STRUCTURE

8.4.2.1 The organization shall implement and maintain a structure, identifying one or more teams responsible for responding to disruptions.

8.4.2.2 The roles and responsibilities of each team and the relationships between the teams shall be

clearly stated.

RESPONSE STRUCTURE (2)

8.4.2.3 Collectively, the teams shall be competent to:

a) assess the nature and extent of a disruption and its potential impact;

b) assess the impact against pre-defined thresholds that justify initiation of a formal response;

c) activate an appropriate business continuity response;

d) plan actions that need to be undertaken;

e) establish priorities (using life safety as the first priority);

f) monitor the effects of the disruption and the organization’s response;

g) activate the business continuity solutions;

h) communicate with relevant interested parties, authorities and the media.

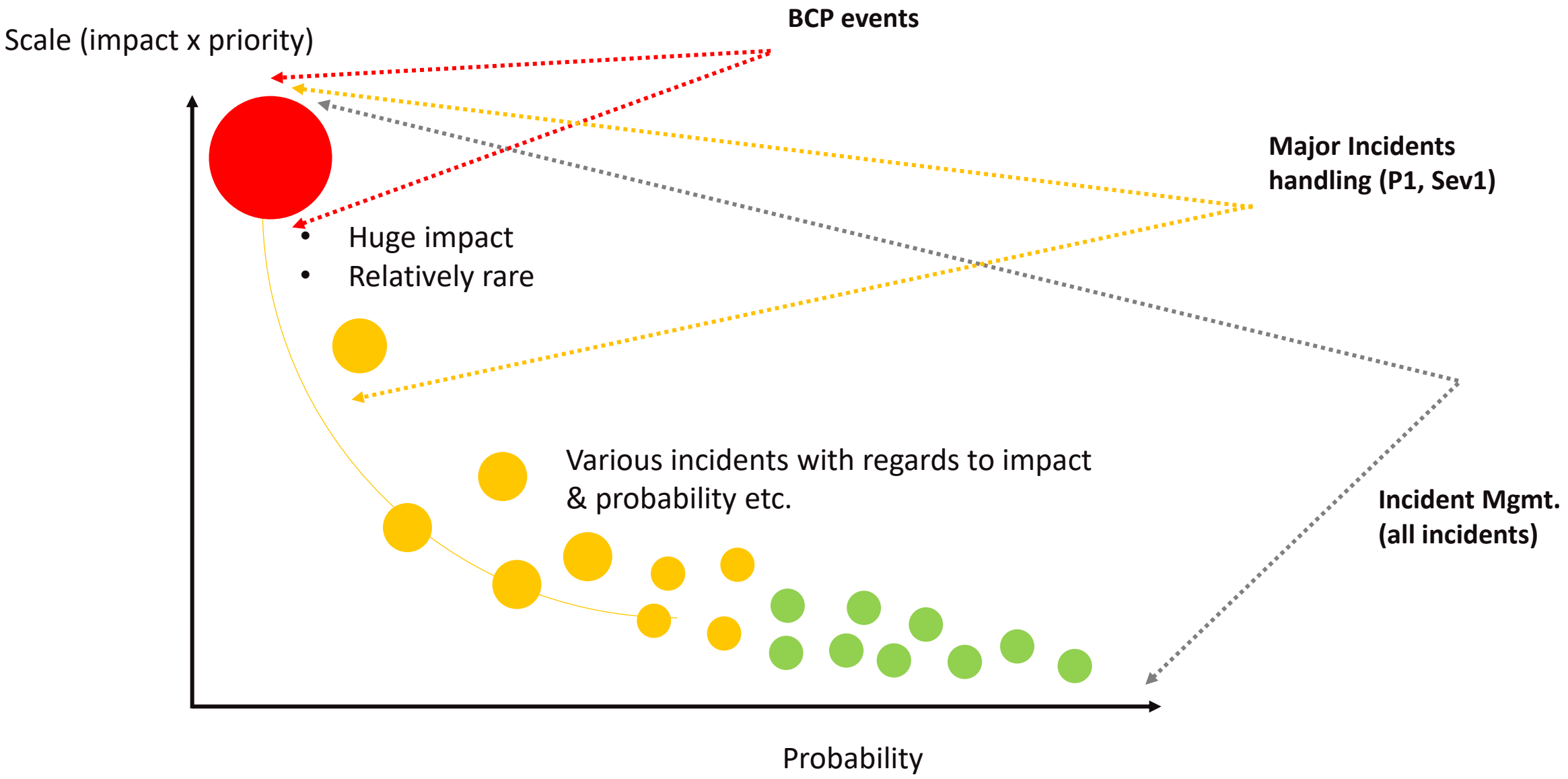
RESPONSE STRUCTURE (3)

8.4.2.4 For each team there shall be:

a) identified personnel and their alternates with the necessary responsibility, authority and competence to perform their designated role;

b) documented procedures to guide their actions (see 8.4.4), including those for the activation, operation, coordination and communication of the response.

BCP EVENTS AND INCIDENTS



BCP EVENTS AND INCIDENTS RESPONSE

Objective: restoration of activities ASAP

NB: there are different definitions of “incident” across standards ISO 9001, ISO 20000, ISO 27001 и ISO 22301

Incident

Time

Assessment and incident response

Within minutes to hours:
- Staff and visitors check
- Check on injured people
- Damage control
- Initial damage evaluation
- BCP activation

BCM

Within hours to days:
- Communication to staff, clients, suppliers etc.
- Critical processes recovery
- Recovery of lost activities and data lost on the fly

Within weeks to months:
- Damage recovery
- Relocation to permanent workplace
- Recovery f expense form insurance companies
- Gathering and evaluation of lessons learned
- New operating model (in case needed)

Recovery of business – back to normal

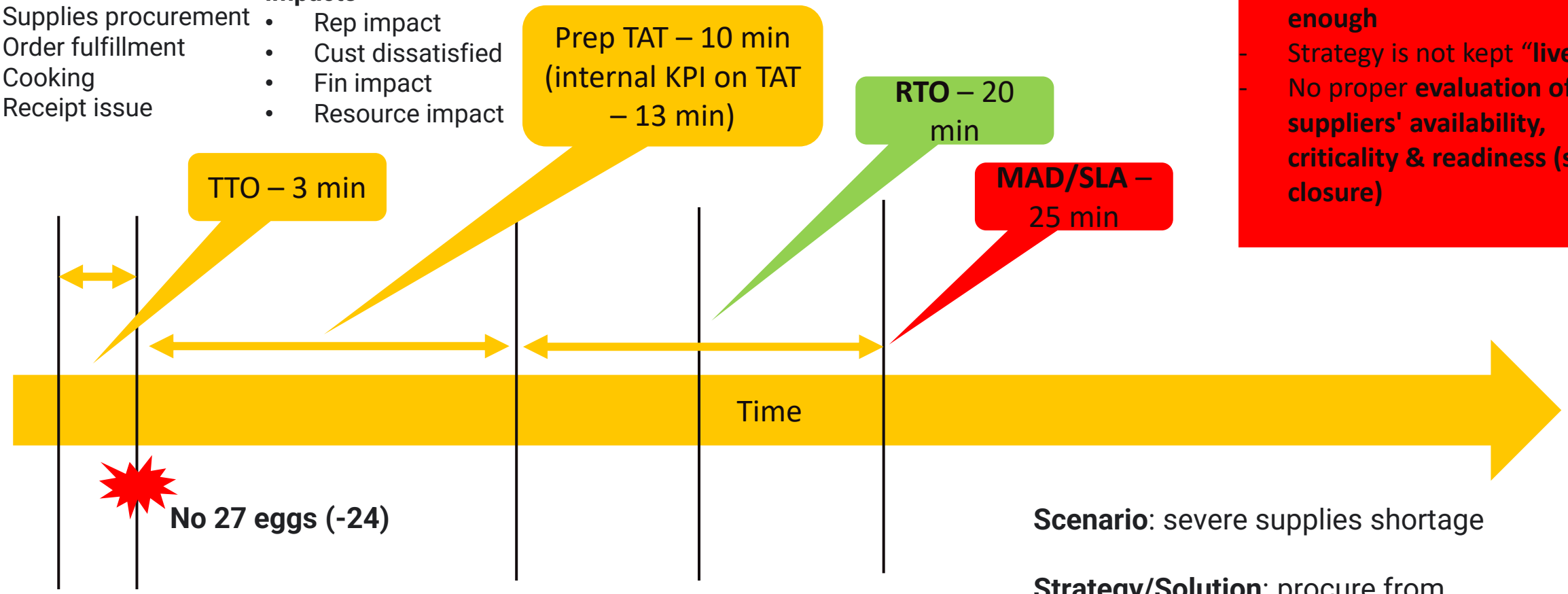
THE POACHED EGGS BCP CASE (NEIGHBORHOOD PUB)

RTO – recovery time objective
MAD – Maximum allowable downtime

- No **proper risk assessment** (Supplier unavailable 14% time)
- Strategy is nor **resourced enough**
- Strategy is not kept "**live**"
- No proper **evaluation of suppliers' availability, criticality & readiness (shop closure)**

Critical processes:
- Supplies procurement
- Order fulfillment
- Cooking
- Receipt issue

Impacts
- Rep impact
- Cust dissatisfied
- Fin impact
- Resource impact



Scenario: severe supplies shortage

Strategy/Solution: procure from Baba Genka (TAT 5 min) – yet she goes 1 day/week to medical care

But she is not available. So you go beyond MAD

- **"Plato & Platypus walk into a bar/pub"** – 9 colleagues x 3 poached eggs servings
- **Capacity related incident > P1 > BCP**

8.4.3 WARNING AND COMMUNICATION

8.4.3.1 The organization shall document and maintain procedures for:

a) communicating internally and externally to relevant interested parties, including what, when, with whom and how to communicate;

NOTE The organization can document and maintain procedures for how, and under what circumstances, the organization communicates with employees and their emergency contacts.

b) receiving, documenting and responding to communications from interested parties, including any national or regional risk advisory system or equivalent;

c) ensuring the availability of the means of communication during a disruption;

d) facilitating structured communication with emergency responders;

e) providing details of the organization’s media response following an incident, including a communications strategy;

f) recording the details of the disruption, the actions taken and the decisions made

8.4 BUSINESS CONTINUITY PLANS AND PROCEDURES

8.4.3.2 Where applicable, the following shall also be considered and implemented:

a) alerting interested parties potentially impacted by an actual or impending disruption;

b) ensuring appropriate coordination and communication between multiple responding organizations.

The warning and communication procedures shall be exercised as part of the organization’s exercise programme described in 8.5.

BUSINESS CONTINUITY PLANS AND PROCEDURES (2)

8.4.4 Business continuity plans

8.4.4.1 The organization **shall document and maintain business continuity plans and procedures.**

The business continuity plans shall provide guidance and information to assist teams to respond to a disruption and to assist the organization with response and recovery

BUSINESS CONTINUITY PLANS AND PROCEDURES (3)

8.4.4.2 Collectively, the business continuity plans shall contain:

a) details of the actions that the teams will take in order to:

1) continue or recover prioritized activities within predetermined time frames;

2) monitor the impact of the disruption and the organization’s response to it;

b) reference to the pre-defined threshold(s) and process for activating the response;

c) procedures to enable the delivery of products and services at agreed capacity;

d) details to manage the immediate consequences of a disruption giving due regard to:

1) the welfare of individuals;

2) the prevention of further loss or unavailability of prioritized activities;

3) the impact on the environment.

BUSINESS CONTINUITY PLANS AND PROCEDURES (4)

8.4.4.3 Each plan shall include:

a) the purpose, scope and objectives;

b) the roles and responsibilities of the team that will implement the plan;

c) actions to implement the solutions;

d) supporting information needed to activate (including activation criteria), operate, coordinate and communicate the team's actions;

e) internal and external interdependencies;

f) the resource requirements;

g) the reporting requirements;

h) a process for standing down.

Each plan shall be usable and available at the time and place at which it is required.

BUSINESS CONTINUITY PLANS AND PROCEDURES (5)

8.4.5 Recovery

The organization shall have documented processes to restore and return business activities from the temporary measures adopted during and after a disruption.

DISCUSSION

Arguing with an auditor is like wrestling with a **pig** in the mud.

After a few minutes you realize the **pig** likes it

8.5 EXERCISE PROGRAMME

The organization shall implement and maintain a programme of exercising and testing to validate over time the effectiveness of its business continuity strategies and solutions. The organization shall conduct exercises and tests that: a) are consistent with its business continuity objectives; b) are based on appropriate scenarios that are well planned with clearly defined aims and objectives; c) develop teamwork, competence, confidence and knowledge for those who have roles to perform in relation to disruptions; d) taken together over time, validate its business continuity strategies and solutions; e) produce formalized post-exercise reports that contain outcomes, recommendations and actions to implement improvements; f) are reviewed within the context of promoting continual improvement; g) are performed at planned intervals and when there are significant changes within the organization or the context in which it operates. The organization shall act on the results of its exercising and testing to implement changes and improvements.

TYPES OF BCP EXERCISE (1)

Category	Method	Description
Discussion	Plan review	Usually an informal review of a plan intended to familiarize participants with new or changed content. They are useful after the initial development of the plan. It can last usually between 1 and 2 hours.
	Tabletop, in situ	Here, simple scenarios are used that familiarize participants with plans and procedures in a very low stress environment. They can also be used to review scenarios and response strategies for validation and improvement. This is the most common type of training and lasts about 2-3 hours.
	Tabletop, out of the usual location	It is usually done at an alternate location or crisis "command center" to review procedures, decisions, and strategies. It usually relies on simple scenarios. The main difference with the previous way is that it is in a different than normal operating environment. It usually lasts about 2-3 hours.
Simulation	Workshop (one or many plans)	They usually take place separately from the normal operating environment with relatively complex scenarios. Depending on the scope, one or more plans are subject to review. The idea is to practice the plan in a situation closer to the real thing and with a higher level of stress.
	Workshop (one or many locations)	There are often many locations here. The idea is for teams to practice working from a different than normal location. 3-5 hours.
	Workshop for the whole organization (comprehensive)	Complex, organization-wide tests that are planned for a long time and can really affect the organization's activities. They take between half a day and a whole week depending on the complexity and number of people.

TYPES OF BCP EXERCISE (2)

Effort

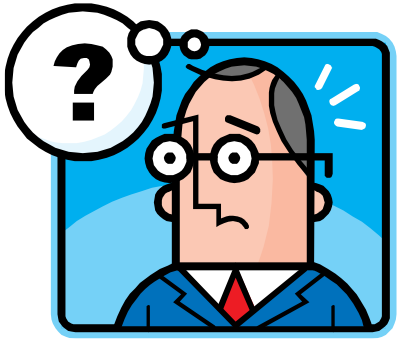
1	2	3
Dry Run	Partial (component) Exercise	Real Simulation

• Virtual meeting between team members, the response team (operational and management)
• Continuity plan discussion
• Limited response scenario – one location, one business process within one business function/organization
• It combines elements of training, awareness and awareness
• Tests understanding of plan components – having a plan, organizational structure, communication matrices, roles and responsibilities
• **The most common type (others are not recommended unless required by legal requirements, customer and contractual compliance)**
	• Similar to option #1
	• Virtual Gathering
	• More focus not on "awareness" and "understanding" of the overall structure, **but on scenarios from components of continuity management:**
	  • Loss of a key dependency
	  • IT system Supplier
	  • Loss of documentation
	  • Location access
	  • Stopping the activity of a component of a given business process, etc.
		• Stopping a real activity component to test the response
		• Stopping an entire business process with its underlying functions in order to test a real response
		• Not recommended by business to avoid real penalties

8.6 EVALUATION OF BUSINESS CONTINUITY DOCUMENTATION AND CAPABILITIES

8.6 Evaluation of business continuity documentation and capabilities The organization shall: a) evaluate the suitability, adequacy and effectiveness of its business impact analysis, risk assessment, strategies, solutions, plans and procedures; b) undertake evaluations through reviews, analysis, exercises, tests, post-incident reports and performance evaluations; c) conduct evaluations of the business continuity capabilities of relevant partners and suppliers; d) evaluate compliance with applicable legal and regulatory requirements, industry best practices, and conformity with its own business continuity policy and objectives; e) update documentation and procedures in a timely manner. These evaluations shall be conducted at planned intervals, after an incident or activation, and when significant changes occur.

EXERCISE

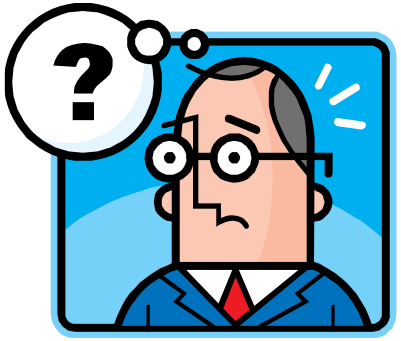


Business Continuity Strategy

A business owner told you he expects 2nd party BCM audit from a client and asked you what is BC Strategy and what kind of related solutions about it he could expect?

Please, explain him

EXERCISE



Business Continuity Plan

A friend of yours was required by local authorities to develop BCP. He asked you to tell him what could he expect in case of inspection?

Please, explain him

intertek

Total Quality. Assured.

SECTION 8
ISO 22301:2019
PERFORMANCE EVALUATION

PURPOSE OF THIS SESSION: TO DESCRIBE CLAUSE 9 OF ISO 22301:2019; TO EXPLAIN INTERNAL AUDIT AND MANAGEMENT REVIEW OF BCMS AIMING TO ENSURE THAT MANAGEMENT MONITOR AND REVIEW THE EFFECTIVENESS AND EFFICIENCY OF THE BCMS AND DETERMINE AND AUTHORIZE ACTIONS FOR REMEDIATION AND IMPROVEMENT

PERFORMANCE EVALUATION

The Purpose is to ensure that management monitor and review the effectiveness and efficiency of the BCMS, review the appropriateness of the business continuity policy, objectives and scope, and determine and authorize actions for remediation and improvement.

(Cl.9)

CL. 9.1 MONITORING, MEASUREMENT, ANALYSIS AND EVALUATION

The organization shall determine:

a) what needs to be monitored and measured;

b) the methods for monitoring, measurement, analysis and evaluation, as applicable, to ensure valid

c) results;

d) c) when and by whom the monitoring and measuring shall be performed;

e) d) when and by whom the results from monitoring and measurement shall be analysed and evaluated.

f) The organization shall retain appropriate documented information as evidence of the results.

g) The organization shall evaluate the BCMS performance and the effectiveness of the BCMS.

CL. 9.2 INTERNAL AUDIT

The organization shall conduct internal audits at planned intervals to provide information on whether the BCMS:

a) conforms to:

1) the organization’s own requirements for its BCMS;

2) the requirements of this document;

b) is effectively implemented and maintained.

CL. 9.2 INTERNAL AUDIT

9.2.2 Audit programme(s) The organization shall: a) plan, establish, implement and maintain an audit programme(s) including the frequency, methods, responsibilities, planning requirements and reporting, which shall take into consideration the importance of the processes concerned and the results of previous audits; b) define the audit criteria and scope for each audit; c) select auditors and conduct audits to ensure objectivity and the impartiality of the audit process; d) ensure that the results of the audits are reported to relevant managers; e) retain documented information as evidence of the implementation of the audit programme(s) and the audit results; f) ensure that any necessary corrective actions are taken without undue delay to eliminate detected nonconformities and their causes; g) ensure that follow-up audit actions include the verification of the actions taken and the reporting of verification results.

CL. 9.3 MANAGEMENT REVIEW

9.3.1 General Top management shall review the organization’s BCMS, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.

9.3.2 MANAGEMENT REVIEW INPUT

The management review shall include consideration of:

a) the status of actions from previous management reviews;

b) changes in external and internal issues that are relevant to the BCMS;

c) information on the BCMS performance, including trends in:

1) nonconformities and corrective actions;

2) monitoring and measurement evaluation results;

3) audit results;

d) feedback from interested parties;

e) the need for changes to the BCMS, including the policy and objectives;

f) procedures and resources that could be used in the organization to improve the BCMS' performance and effectiveness;

g) information from the business impact analysis and risk assessment;

h) output from the evaluation of business continuity documentation and capabilities (see 8.6);

i) risks or issues not adequately addressed in any previous risk assessment;

j) lessons learned and actions arising from near-misses and disruptions;

k) opportunities for continual improvement.

9.3.3 MANAGEMENT REVIEW OUTPUTS

9.3.3 Management review outputs

9.3.3.1 The outputs of the management review shall include decisions related to continual improvement opportunities and any need for changes to the BCMS to improve its efficiency and effectiveness, including the following:

a) variations to the scope of the BCMS;

b) update of the business impact analysis, risk assessment, business continuity strategies and solutions, and business continuity plans;

c) modification of procedures and controls to respond to internal or external issues that may impact the BCMS;

d) how the effectiveness of controls will be measured.

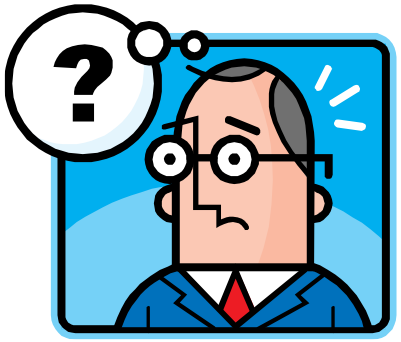
9.3 MANAGEMENT REVIEW

9.3.3.2 The organization shall retain documented information as evidence of the results of management reviews. It shall:

a) communicate the results of the management review to relevant interested parties;

b) b) take appropriate action relating to those results.

EXERCISE



Management review

You are new member of the Board of Director of company, which expects BCMS 3rd party audit. You were required to organize BCMS Management review

Please explain:

- What should be provided as an input to the Management review?
- What should be the output?

intertek

Total Quality. Assured.

SECTION 9
ISO 22301:2019
IMPROVEMENT

PURPOSE OF THIS SESSION: TO DESCRIBE CLAUSE 10 OF ISO 22301:2019; TO EXPLAIN CORRECTIVE ACTIONS.

NONCONFORMITY AND CORRECTIVE ACTION (1)

When nonconformity occurs, the organization shall

- identify the nonconformity,
- react to the nonconformity, and, as applicable,
  1) take action to control and correct it,
  2) deal with the consequences.

(Cl.10.1)

NONCONFORMITY AND CORRECTIVE ACTION (2)

When nonconformity occurs, the organization shall

evaluate the need for action to eliminate the causes of the nonconformity, by

- reviewing the nonconformity,
- determining the causes of the nonconformity,
- evaluating the need for corrective action,
- determining and implementing corrective action,
- reviewing the effectiveness the corrective action
- making changes to the BCMS, if necessary.

NONCONFORMITY AND CORRECTIVE ACTION (3)

Corrective actions shall be appropriate to the effects of the nonconformities encountered.

The organization shall retain documented information as evidence of

- the nature of the nonconformities and any subsequent actions taken,
- the results of any corrective action.

(Cl.10.1)

CONTINUAL IMPROVEMENT

The organization shall continually improve the suitability, adequacy or effectiveness of the BCMS.

The organization can use the processes of the BCMS such as

- leadership,
- planning and
- performance evaluation,

to achieve improvement.

(Cl.10.2)

intertek

Total Quality. Assured.

SECTION 10
ISO 22301:2012
LEGAL COMPLIANCE

PURPOSE OF THIS SESSION: RAISE THE AWARENESS OF THE DELEGATES ON THE PRINCIPAL APPLICABLE NATIONAL AND INTERNATIONAL LEGISLATION RELATED TO BCM AND THE PRINCIPAL REGULATORY COMPLIANCE AUDITING METHODS.

LEGAL CONFORMANCE VS. STANDARD CONFORMANCE

Make difference between legal compliance and conformance with ISO 22301:2019 standard!

If the legal environment requires the organization to implement any Business Continuity measures, these MUST BE IMPLEMENTED!

Compliance with ISO 22301:2019 cannot confer immunity from legal obligations.

HOW LEGAL, REGULATORY OR CONTRACTUAL REQUIREMENTS IMPACT THE ORGANIZATION?

Auditors should focus on:

- Has the organization identified Legal, Regulatory, contractual requirements to BCMS?

  International/National/Local law/regulations in BC and

  Disaster recovery (DR); Licenses; Statute; Ecology

  Service Level Agreements, Insurance, Utilities

- Has the organization established the required BCM arrangement with Emergency service, Police, DR agencies, Trade Unions, State agencies, and the like
- The supply chain

HOW LEGAL, REGULATORY OR CONTRACTUAL REQUIREMENTS IMPACT THE INTERESTED PARTIES?

Auditors should focus on:

- Has the organization identified the interested parties?
    - e.g. shareholders, insurance companies, state agencies, employees' families, stock exchange, fire brigade
    - Municipalities, organizations along the supply chain

- Has the organization implemented the necessary BCM arrangements?

WHO IS RESPONSIBLE FOR THE LEGAL COMPLIANCE?

The Maintenance and Evaluation of Legal Compliance is Responsibility of the Organization

The certification/registration body is restricted to checks and samples to establish confidence that the BCMS functions in this regard.

THE ROLES

An organization with a certified/registered BCMS guarantees continuing compliance with regulatory requirements applicable to the business continuity impacts of its activities, products and services.

The certification/registration body confirms that a system capable of achieving the required compliance Is fully implemented.

THE CERTIFICATION/REGISTRATION BODY

Verifies that the organization:

Has evaluated legal and regulatory compliance and

Can show that action is taken in case of non-compliance with relevant regulations.

IDENTIFICATION OF APPLICABLE LEGISLATION

The organization should explicitly define and document the statutory, regulatory and contractual requirements and any Business Continuity requirements applicable to the organization’s BCMS.

THE BCMS COULD CONTAIN

A matrix of all the compliance requirements for each process.

Documented specific controls and individual responsibilities to meet them.

APPLICABLE MIGHT BE

Domestic rules: statutory and normative requirements, secondary legislation and technical requirements

Foreign legislation: international and bilateral agreements

EU legislation

RELEVANT LEGISLATION

Needs to be interpreted in line with supporting acts

And with EU perspective in mind

Needs further investigation by qualified legal advisers in the organization

LEGAL/REGULATORY ZONES WHICH COULD DEFINE BC REQUIREMENTS

- Telecommunications
- Licenses issued to telecom operators
- Trade Law
- Homeland Security
- Banking law
- e-Signature & e-Documents law
- Environment protection law

LEGAL/REGULATORY ZONES ….

- E-Payment instruments
- Accounting Law/Best practice
- Power generation
- Utilities
- Oil & Gas drilling
- Air Traffic Control
- Sea Law

LEGAL/REGULATORY ZONES ….

- Local Governance
- Mining
- Public Transport
- Health Care
- Disaster Recovery
- Licenses, regulations for specific industries, etc.

IMPORTANT!

Legal Requirements

- Failure to comply with legal requirements may result in a fine or imprisonment.

Conformance to ISO Standards

- Failure to comply with ISO Standard 3rd Party Certification requirement may lead to loss of registration.

- Failure to comply with ISO Standard where the requirements are contractually binding may result in being fined by the Civil Court.

intertek

Total Quality. Assured.

SECTION 11 ACCREDITATION, CERTIFICATION AND TYPES OF AUDIT

PURPOSE OF THIS SESSION: TO DEFINE ACCREDITATION AND CERTIFICATION AND THE BODIES INVOLVED; TO DISTINGUISH BETWEEN THE VARIOUS TYPES OF AUDITS.

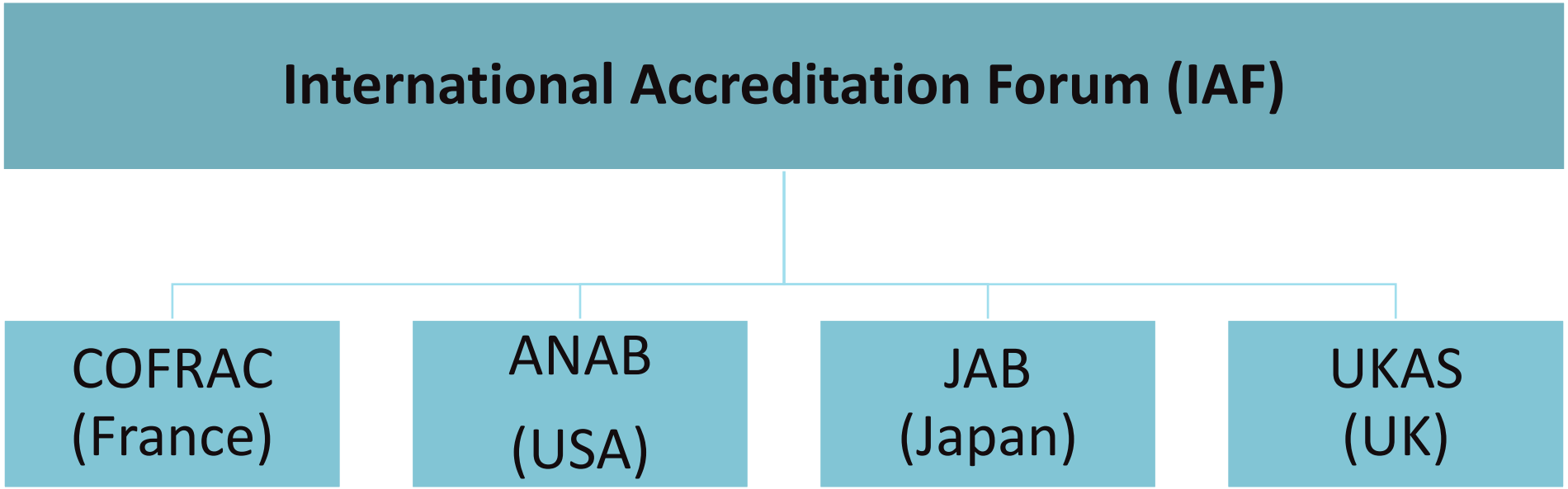
THE STANDARDS

ACCREDITATION

- Provided by accreditation bodies
- Competence recognized by an authorized (national) accreditation body

ACCREDITATION

MULTILATERAL AGREEMENTS (MLA)



ACCREDITATION

European Cooperation for Accreditation

Oversight and control over the accreditation activities in the European Union

ACCREDITATION

National Accreditation Body

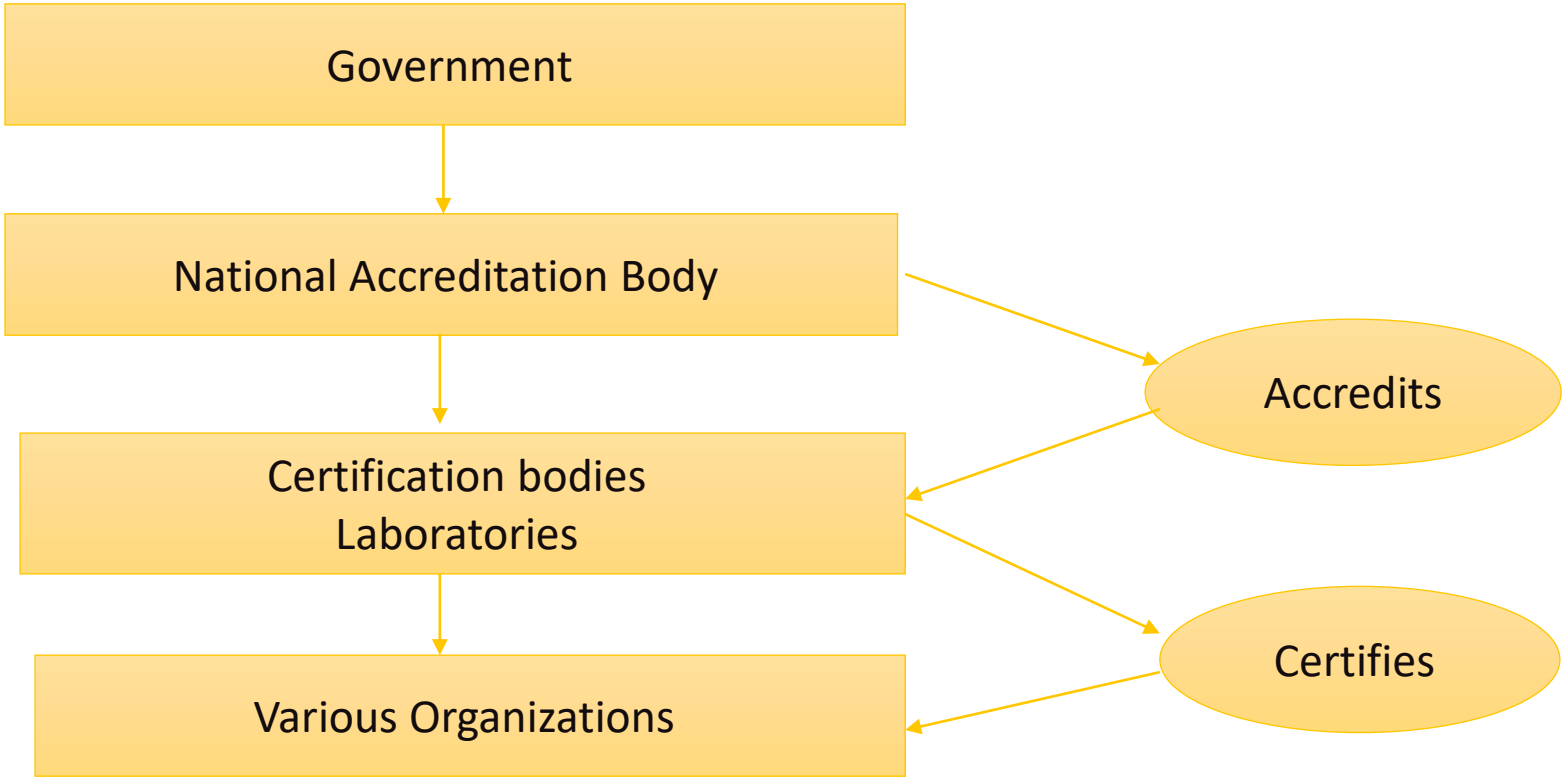
Certification Bodies

INTK

INTK

INTK

ACCREDITATION SCHEME



BENEFITS OF ACCREDITATION

Competence of CB recognized and confirmed

Complaints management

BENEFITS OF CERTIFICATION

Provides confidence in clients and partners that the management system is compliant with the respective standard

Opportunities for improvement identified

Other (please use the flipchart and list at least 3 benefits)

AUDITOR REGISTRATION SCHEME

The Chartered Quality Institute & International
Register of
Certified Auditors

Lead Auditor/ Auditor and Internal Auditor Training Organisations

Principal/Lead Auditor Auditor Registration

Internal Auditor Registration

*Find more on https://www.quality.org/

TYPES OF AUDITS

According to the parties involved:

1st Party	• Internal audits
2nd Party	• Customer audit of a supplier or a potential supplier
3rd Party	• Audit by an independent third party

SCOPE OF 19011 AND ITS RELATIONSHIP WITH ISO/IEC 17021

ISO 19011 concentrates on internal audits (first party) and audits conducted by organizations on their external providers and other external interested parties (second party). ISO 19011 can also be useful for external audits conducted for purposes other than third party management system certification. ISO/IEC 17021-1 provides requirements for auditing management systems for third party certification; ISO 19011 can provide useful additional guidance

1st party audit	2nd party audit	3rd party audit
Internal audit	External provider audit	Certification and/or accreditation audit
	Other external interested party audit	Statutory, regulatory and similar audit

THIRD PARTY AUDITS ACCORDING TO 17021:2015

Audit carried out by an auditing organization independent of the client and the user, for the purpose of certifying the client's management system

NOTE 1 – In the definitions which follow, the term “audit” has been used for simplicity to refer to third-party certification audit.

NOTE 2 – Third-party certification audits include initial, surveillance, re-certification audits, and can also include special audits.

THIRD PARTY AUDITOR

NOTE 3 - Third-party certification audits are typically conducted by audit teams of those bodies providing certification of conformity to the requirements of management system standards.

NOTE 4 - A joint audit is when two or more auditing organizations cooperate to audit a single client.

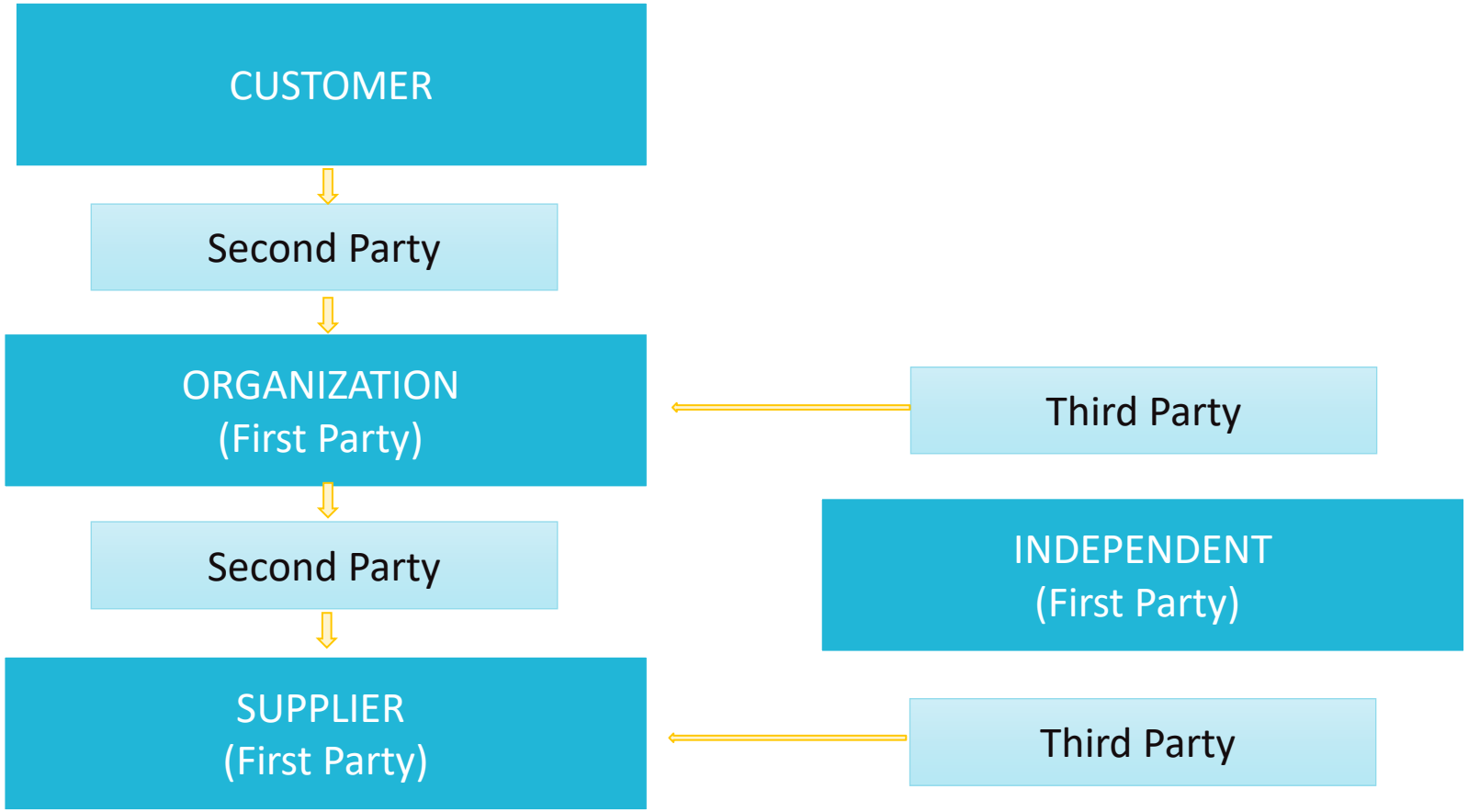
NOTE 5 - A combined audit is when a client is being audited against the requirements of two or more management systems standards together.

NOTE 6 - An integrated audit is when a client has integrated the application of requirements of two or more management systems standards into a single management system and is being audited against more than one standard.

DISCUSSION

1. Explain the differences between First, Second and Third Party Audits.
2. Give the example of each party

ASSESSMENT PARTIES



OTHER TYPES OF AUDITS

According to Objectives and Methods:

Document Review	• To determine the extent to which the documentation complies with the requirements
Compliance Audit	• To determine that the system is being implemented in compliance with the requirements
Surveillance	• To determine whether the system continues to meet the specified requirements

APPLICABLE AUDIT METHODS – ISO 19011:2018

Extent of involvement between the auditor and the auditee	Location of the auditor	
	On-site	**Remote**
Human interaction	Conducting interviews. Completing checklists and questionnaires with auditee participation. Conducting document review with auditee participation. Sampling.	Via interactive communication means: — conducting interviews; — observing work performed with remote guide; — completing checklists and questionnaires; — conducting document review with auditee participation.
No human interaction	Conducting document review (e.g. records, data analysis). Observation of work performed. Conducting on-site visit. Completing checklists. Sampling (e.g. products).	Conducting document review (e.g. records, data analysis). Observing work performed via surveillance means, considering social and legal requirements. Analysing data.
On-site audit activities are performed at the location of the auditee. Remote audit activities are performed at any place other than the location of the auditee, regardless of the distance. Interactive audit activities involve interaction between the auditee's personnel and the audit team. Non-interactive audit activities involve no human interaction with persons representing the auditee but do involve interaction with equipment, facilities and documentation.		

EXERCISE

Team Work (15 minutes)

The tutor will prepare a slips of paper with the following methods of audit:

- On site Audit with human interaction
- On site Audit without human interaction
- Remote audit with human interaction
- Remote audit without human interaction

Each team need to choose one of the papers and present the benefits of it.

The team with the longest list wins!

intertek

Total Quality. Assured.

SECTION 12
AUDIT PROCESS AND PLANNING

PURPOSE OF THIS SESSION: TO BE ABLE TO DEFINE ALL ELEMENTS OF AN AUDIT; TO DEVELOP LEAD AUDITOR SKILLS THROUGH ACCURATE AND DETAILED PLANNING

MAIN DOCUMENTS TO BE CONSIDERED

- ISO 17021: 2015 - Third Party Audit Requirements
- ISO 19011: 2018 - Auditing Guidelines
- Requirements of the management system standard

ISO 19011: 2018 GUIDELINES FOR MANAGEMENT SYSTEMS AUDITING

- ISO 19011 (does not state requirements) provides guidance:
- on the management of an audit programme,
- on the planning and conducting of an audit of the management system,
- on the competence and evaluation of an auditor and an audit team.

NB: The new version covers all disciplines whereas the previous version covered only quality and environmental

THE PURPOSE OF ISO/IEC 17021

- This International Standard specifies requirements for certification bodies.
- Aims to ensure that certification bodies operate management system certification in a competent, consistent and impartial manner.
- This International Standard serves as a foundation for facilitating the recognition of management system certification in the interests of international trade.

AUDIT STAGES

Planning	• Pre-audit activities • Audit Planning
Implementation	• On-site audit – Stage 1 and Stage 2 activities
Reporting and Follow Up	• Reporting • Follow up

PLANNING: PRE-AUDIT ACTIVITIES

- Application
- Application review
- Audit Programme
- Determining audit time
- Multi-site sampling
- Multiple management systems standards

APPLICATION

Applicant organization to provide the necessary information to enable it to establish the following:

Scope

Name, address

Processes and operations

Relevant legal obligations

AUDIT PROGRAMME ISO 19011:2018

All audits in a given audit cycle

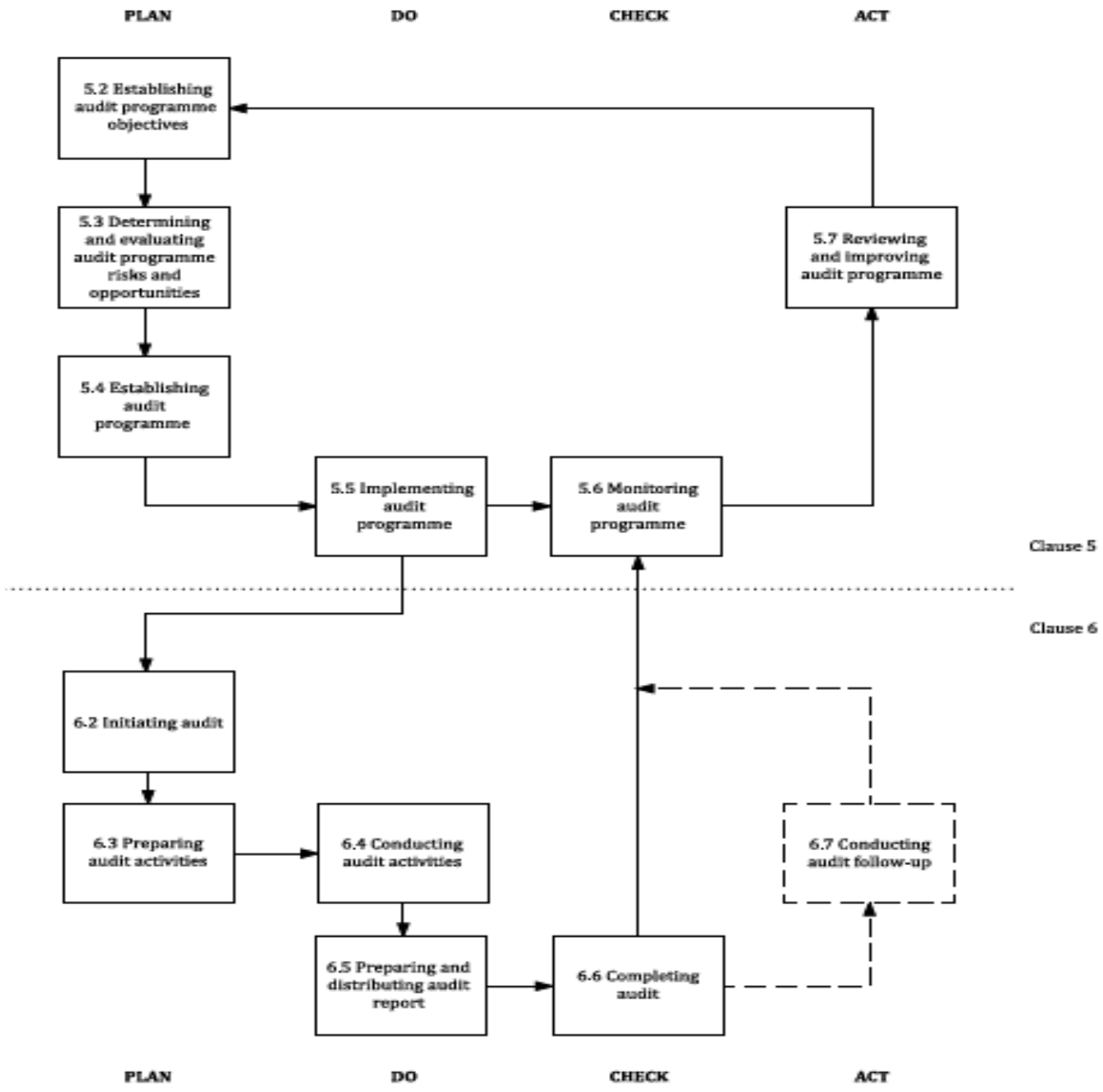
Extent of an audit programme should be based on the size and nature of the auditee, as well as on the nature, functionality, complexity, the type of risks and opportunities, and the level of maturity of the management system(s) to be audited.

When planning the audit programme, Risk-based approach must be considered

Also the following shall be considered:

- Status and importance of processes
- Major changes
- Previously established non-conformities

AUDIT PROGRAMME
ISO 19011



AUDIT PROGRAMME ISO 17021-1:2015

The Audit Programme shall include a two-stage initial audit, surveillance audits in the first and second years, and a recertification audit in the third year prior to expiration of certification. The three-year certification cycle begins with the certification or recertification decision.

The determination of the audit programme and any subsequent adjustments shall consider the size of the client, the scope and complexity of its management system, products and processes as well as demonstrated level of management system effectiveness and the results of any previous audits.

DETERMINING AUDIT TIME

Consideration should be given to:

a) the requirements of the relevant management system standard;

b) complexity of the client and its management system;

c) technological and regulatory context;

d) any outsourcing of any activities included in the scope of the management system;

e) the results of any prior audits;

f) size and number of sites, their geographical locations and multi-site considerations;

g) the risks associated with the products, processes or activities of the organization;

h) whether audits are combined, joint or integrated

DETERMINING AUDIT DURATION

- The “IAF MD 5:2019 Determination of Audit Time of Quality, Environmental, and Occupational Health & Safety Management Systems” provides:
  - guidance and methodology for calculating audit duration
- It’s applicable for any type of audit
- The Audit duration depends of 2 parameters
  - Personnel in the scope of the management system
  - Complexity of the processes
- Usually the certification body has methodology developed upon the above IAF’s document

MULTI-SITE SAMPLING

Where multi-site sampling is used for the audit of a client’s management system covering the same activity in various geographical locations, a sampling programme to ensure proper audit of the management system.

Where there are multiple sites not covering the same activity sampling is not appropriate

Multiple management systems standards

When certification to multiple management system standards is being provided by the certification

body, the planning for the audit shall ensure adequate on-site auditing to provide confidence in the

certification.

PLANNING THE AUDIT: AUDITS OBJECTIVES, SCOPE AND CRITERIA ISO 17021

Audit Objective

Shall be determined by the certification body. The audit scope and criteria, including any changes, shall be established by the certification body after discussion with the client.

Audit Scope

Shall describe the extent and boundaries of the audit, such as sites, organizational units, activities and processes to be audited. Where the initial or re-certification process consists of more than one audit (e.g. covering different sites), the scope of an individual audit may not cover the full certification scope, but the totality of audits shall be consistent with the scope in the certification document

Audit criteria

- the requirements of a defined normative document on management systems
- the defined processes and documentation of the management system developed by the client.

AUDITS OBJECTIVES, SCOPE AND CRITERIA – ISO/IEC 19011

Audit objectives:

Define what is to be accomplished by the individual audit

Audit criteria

Used as a reference against which conformity is determined and may include:

- Applicable policies,
- Procedures,
- Standards,
- Work instructions
- Legal requirements,
- Management system requirements,

COMPETENCY OF AUDIT TEAM

- **Generic knowledge and skills of management system auditors**
- **Audit principles, procedures and methods** - to apply the appropriate principles, procedures and methods to different audits, and to ensure that audits are conducted in a consistent and systematic manner
- **Management system and reference documents** - to comprehend the audit scope and apply audit criteria
- **Organizational context** - to comprehend the auditee's structure, business and management practices
- **Applicable legal and contractual requirements and other requirements that apply to the auditee** - to be aware of, and work within, the organization's legal and contractual requirements.

PLANNING: AUDIT PLAN

The audit plan shall be appropriate to the objectives and the scope of the audit and include or refer to the following

a) the audit objectives;

b) the audit criteria;

c) the audit scope, including identification of the organizational and functional units or processes to be audited;

d) the dates and sites where the on-site audit activities will be conducted, including visits to temporary sites and remote auditing activities, where appropriate;

e) the expected duration of on-site audit activities;

f) the roles and responsibilities of the audit team members and accompanying persons, such as observers or interpreters.

STAGE 1 AUDIT

Purpose – to confirm that company's BCMS policy, manual and procedures meet the minimum requirements of the standard.

Activities

- To audit the auditee's BCMS documentation
- To evaluate physical locations and site-specific conditions and to determine the preparedness for the stage 2 audit
- To review the auditee status and understanding according to standard's requirements
- To collect necessary information, including statutory, legal and regulatory requirements
- To evaluate internal audits
- To prepare for Stage 2

It is recommended to conduct part of Stage 1 audit at auditee premises

STAGE 1 AUDIT – OUTPUT

- Audit schedule “the Stage 2” plan
- Verified ‘Scope’ statement
- Verified resources
- Verified BCMS documentation (Manual, Procedures)
- State of Management ‘Readiness’
- Findings of Evaluation

STAGE 2 AUDIT

Purpose of the stage 2

To evaluate the implementation, including effectiveness, of the client's management system.

The stage 2 audit shall take place at the site(s) of the client.

It shall include:

- information and evidence about conformity to all requirements of ISO 22301 standard or other normative document; performance monitoring, measuring, reporting and reviewing against key performance objectives and targets;
- the client's management system and performance as regards legal compliance; operational control of the client's processes;
- internal auditing and management review;
- management responsibility, etc.

INITIAL CERTIFICATION AUDIT CONCLUSIONS

The audit team shall analyze all information and audit evidence gathered during the stage 1 and stage 2 audits to review the audit findings and agree on the audit conclusions.

The audit team shall provide to CB the information necessary for certification decision: the audit reports; comments on non-conformities; correction and corrective actions taken by clients; recommendations whether or not to grant certification.

SURVEILLANCE

Surveillance activities

Representative areas and functions in the scope of BCMS shall be monitored at planned periods, taking into account changes at the client or the BCMS

Surveillance audits

On-site audit, not necessarily the full BCMS audits

Shall be planned together with other surveillance activities in order to keep CB confident that the certified BCMS fulfils ISO 22301 requirements

RECERTIFICATION

The purpose of the recertification audit is to confirm the continued conformity and effectiveness of the ISMS as a whole, and its continued relevance and applicability for the scope of certification

It is a full BCMS audit; The recertification audit shall include an on-site audit information for granting recertification

The certification body shall make decisions on renewing certification based on the results of the recertification audit, as well as the results of the review of the system over the period of certification and complaints received from users of certification

(ON-SITE) AUDIT ACTIVITIES

- Preparing working documents
- Conducting opening meeting
- Communication
- Role of the Guides
- Collection of objective evidence
- Audit conclusion and recommendations
- Conducting closing meeting
- Follow up

PROCESS APPROACH TO AUDITING

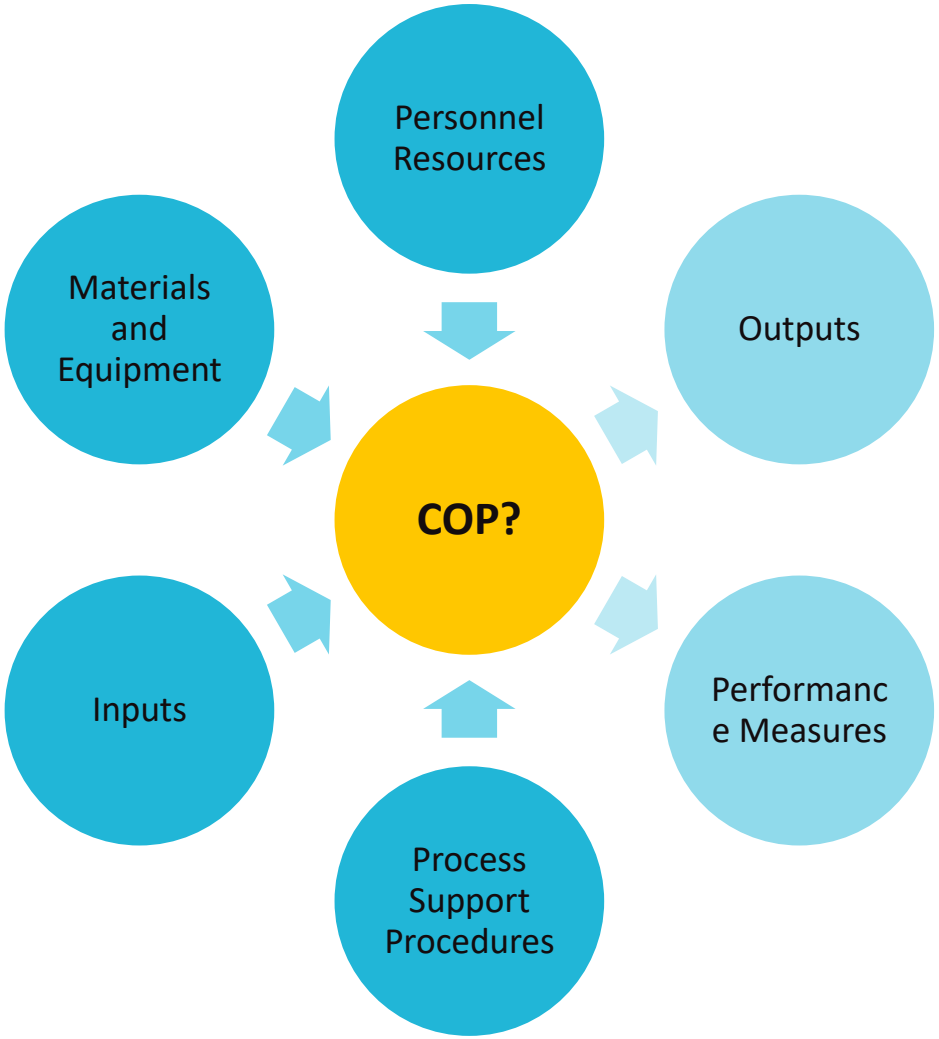
Any activity that receives inputs and converts them to outputs

A process may therefore cover all the activities of a company

THE TURTLE DIAGRAM PROCESS PLAN

Objective:

Owner:



REPORTING & FOLLOW UP

Reporting

- Prepare the audit report
- Approve and distribute the audit report

Follow up

- Check the effectiveness of corrective actions implemented
- Plan for next audit
- Compile the audit file

FIRST AND SECOND PARTY AUDITS

The management of 1st and 2nd party Audit planning and execution should call upon the skills and techniques identified in the previous slides.

OTHER TYPES OF AUDITS…

Combined audits – the same organization has developed two or more types of management systems (BCM, Quality, ISMS, EnMS) – the audits of all are planned at the same time – which would allow for the joint assessment of some system elements and more efficient use of audit time.

OTHER TYPES OF AUDITS…

Integrated audits – audits of an integrated management system that complies with more than one management system standard. Level of possible reduction of audit time depends on:

- Level of integration of the systems
- Competence of the staff of the organization
- Competence of the audit team

intertek

Total Quality. Assured.

SECTION 13
CHECKLISTS

PURPOSE OF THIS SESSION: TO ACQUIRE PRE-AUDITING SKILLS FOR PRODUCING AND USING CHECKLISTS

CHECKLISTS

- Used by the auditor as an Aide Memoir and an audit trace record
- Are compiled from the results of a detailed study of the process descriptions, procedures and the standard
- Used to ensure that all elements and relevant requirements contained in the standard are covered and nothing is omitted

CHECKLISTS

- Used to reference each question to the relevant clauses of the standard
- Are an invaluable aid when writing the audit report.
- Space should be left on the checklist so that answers to the questions can be noted for later use.

SAMPLING

- Considerations
- Scope
- Duration of Audit
- Requirements of the standard
- Level of potential risk
- Previous Problems
- Important Aspects
- Sample size and its significance
- Corporate Issues

Sampling Benefits – more efficient use of time

Sampling Limitations – not all items are checked

SAMPLE CHECKLIST

Standard:	Type of Audit:				
Client:	Auditor:	Date:			
Requirements	OK	CAR	Obs	N/A	Objective Evidence

intertek

Total Quality. Assured.

SECTION 14
OPENING MEETING

PURPOSE OF THIS SESSION: TO BE ABLE TO LIST AND STRUCTURE AN OPENING MEETING AGENDA.

THE OPENING MEETING

Punctuality is important! Arrive on time

The meeting should be brief and to the point

See ISO 19011:2018 for more guidance and all the details.

THE OPENING MEETING

- introduce the audit team
- confirm the objective, scope and criteria
- confirmation of the audit plan (including type and scope of audit, objectives and criteria), any changes, and other relevant arrangements with the client, such as the date and time for the closing

meeting, interim meetings between the audit team and the client’s management

- confirmation of formal communication channels between the audit team and the client confirmation that the resources and facilities needed by the audit team are available confirmation of matters relating to confidentiality

THE OPENING MEETING

- confirmation of relevant work safety, emergency and security procedures for the audit team;
- confirmation of the availability, roles and identities of any guides and observers;
- the method of reporting, including any grading of audit findings;
- information about the conditions under which the audit may be prematurely terminated;
- confirmation of the status of findings of the previous review or audit, if applicable;
- methods and procedures to be used to conduct the audit based on sampling;
- opportunity for the client to ask questions.

intertek

Total Quality. Assured.

SECTION 15
AUDIT TECHNIQUES

PURPOSE OF THIS SESSION: TO BE ABLE TO LIST AND USE THE WORDS NECESSARY TO LOCATE OBJECTIVE EVIDENCE WITHIN AN AUDITOR'S CODE OF CONDUCT. TO BE ABLE TO LIST AND EXPLAIN VERTICAL, HORIZONTAL, FORWARD AND BACKWARDS AUDITING TRAILS. TO RECOGNIZE AND HANDLE AUDITEE DELAYING TECHNIQUES.

PRINCIPLES OF AUDITING – ISO 19011

- **Integrity**: the foundation of professionalism;
- **Fair presentation**: the obligation to report truthfully and accurately;
- **Due professional care**: the application of diligence and judgement in auditing;
- **Confidentiality**: security of information;
- **Independence**: the basis for the impartiality of the audit and objectivity of the audit conclusions;
- **Evidence-based approach**: the rational method for reaching reliable and reproducible audit conclusions in a systematic audit process;
- **Risk-based approach**: an audit approach that considers risks and opportunities.

AUDITOR CHARACTERISTICS

The personal attributes an auditor needs to develop :

- Ethical
- Open minded
- Diplomatic
- Observant
- Perceptive
- Versatile
- Tenacious
- Decisive
- Self-reliant

ROLES, RESPONSIBILITIES, COMPETENCE REQUIREMENTS

- LEAD AUDITORS
- AUDITORS
- TECHNICAL EXPERTS
- AUDITEES

LEAD AUDITOR RESPONSIBILITIES

- A person qualified and authorised to manage a system Audit.
- Plan the Audit and organise a team to conduct the audit – contact the clients, agrees dates, prepare audit/working documents
- Manage all aspects of the Audit ‘on site’ – opening meeting, team meeting, examine documents, observes activities, check documented information's, etc…
- Report the audit - surmises any findings and positive points, writes and issues a summary report
- Close the audit – Considers the corrective action proposals and evidence submitted by the auditee. Judges adequacy of root cause analysis. Accept or rejects these

AUDITOR RESPONSIBILITIES

- A person qualified and authorised to perform all, or a portion of, an audit.
- To audit allocated areas/ activities and report findings to the Lead Auditor.
- Be aware of the needs and expectation of the Auditee.
- Consider local culture and customs.

AUDITEE'S RESPONSIBILITIES

- Co-operate with the Auditor in the planning and conducting of the Audit.
- Provide access for the Audit team.
- Provides guides.
- Attend the opening and closing meetings.
- Address and implement corrective action.

OBSERVER AND TECHNICAL EXPERT

Observers

The presence and justification of observers during an audit activity shall be agreed to by the certification body and client prior to the conduct of the audit. The audit team shall ensure that observers do not unduly influence or interfere in the audit process or outcome of the audit.

Technical experts

The role of technical experts during an audit activity shall be agreed to by the certification body and client prior to the conduct of the audit. A technical expert shall not act as an auditor in the audit team. The technical experts shall be accompanied by an auditor.

GUIDES

The responsibilities of a guide can include:

a) establishing contacts and timing for interviews;

b) arranging visits to specific parts of the site or organization;

c) ensuring that rules concerning site safety and security procedures are known and respected by the audit team members;

d) witnessing the audit on behalf of the client;

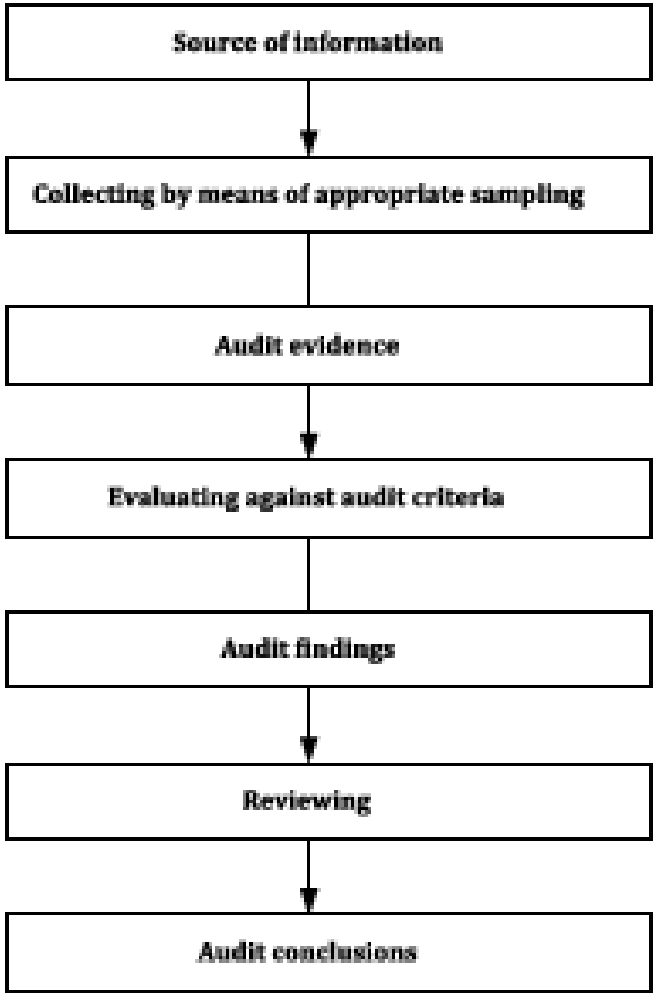
e) providing clarification or information as requested by an auditor.

Where appropriate, the auditee can also act as the guide.

AUDIT TECHNIQUES

- Interview
- Observation of processes and activities
- Review of documentation and records
- Review of documented information
- Examine Objective Evidence
- Observe Activities
- Listen to Reactions
- Record Findings

TYPICAL PROCESS OF COLLECTING AND VERIFYING INFORMATION



DEALING WITH PROBLEMS

Auditors may not always receive full co-operation from the Auditee, it is therefore important to recognise when such situations are occurring and take appropriate action.

Such instances may include:

- Avoid answering questions
- Going missing
- Delaying the Audit
- Constant interruptions, etc.

THE AUDITORS SIX FRIENDS

When asking questions…..

- Who ?
- What ?
- Where ?
- When ?
- Why ?
- How ?

- and the seventh ….. Ok Show Me ?

QUESTION TECHNIQUE

YES / NO Questions

- Often elicit dead end answers - you gain nothing –
- Only useful as a leader question.

How - What - Why - When - Where - Who ?

- Direct questions - will achieve more detailed
- answers.

Explanation Questions

- Useful for comparing interfaces.

QUESTIONING TECHNIQUES IN AUDIT INTERVIEW (BEST PRACTICES)

Through Questioning, auditors have to zero down the conversations in a FRIENDLY MANNER, to witness / verify evidences to reach an audit conclusion on degree of compliances

Qs. Type	Sample	Expected Answer	Cautions during asking
Open Qs.	What is the system you maintain here?	This is a lab where we **quality testing & calibrate** measuring instruments	Auditee may go into defensive mode – mainly with closed questions
Probing Qs.	Which acceptance criteria you use for **quality inspections** ?	Every product have different **standards which are acceptance criteria** for quality	
Closed	Could you please show me some **records to evidence** the same	**NOW AUDITEE HAS TO SHOW THE EVIDENCE**	

COMMUNICATIONS IN AUDITS – BODY LANGUAGE (BEST PRACTICES)

Friendly	Body Language	Non Friendly
Smiling	Facial	Tight Lipped
Relaxed Mouth		Grim Smile
Alert		Raised Eyebrows
Ready to Listen		Jaw Muscles Clenched
Pupils Dilated	Eyes	Looking Down Nose
Good Contact		Lack of Contact
Wide Open		Narrowed
Straight	Head	Bowed
Mildly Nodding		Shaking
Open	Body Position	Crossed Arms
Erect		Legs Crossed Away
Leaning Forward		Cold Shoulder
Open Hands	Hand Gestures	Tapping Fingers
Touching		Closed Hands
Hand to Chest		Finger Wagging

QUESTIONING TECHNIQUES

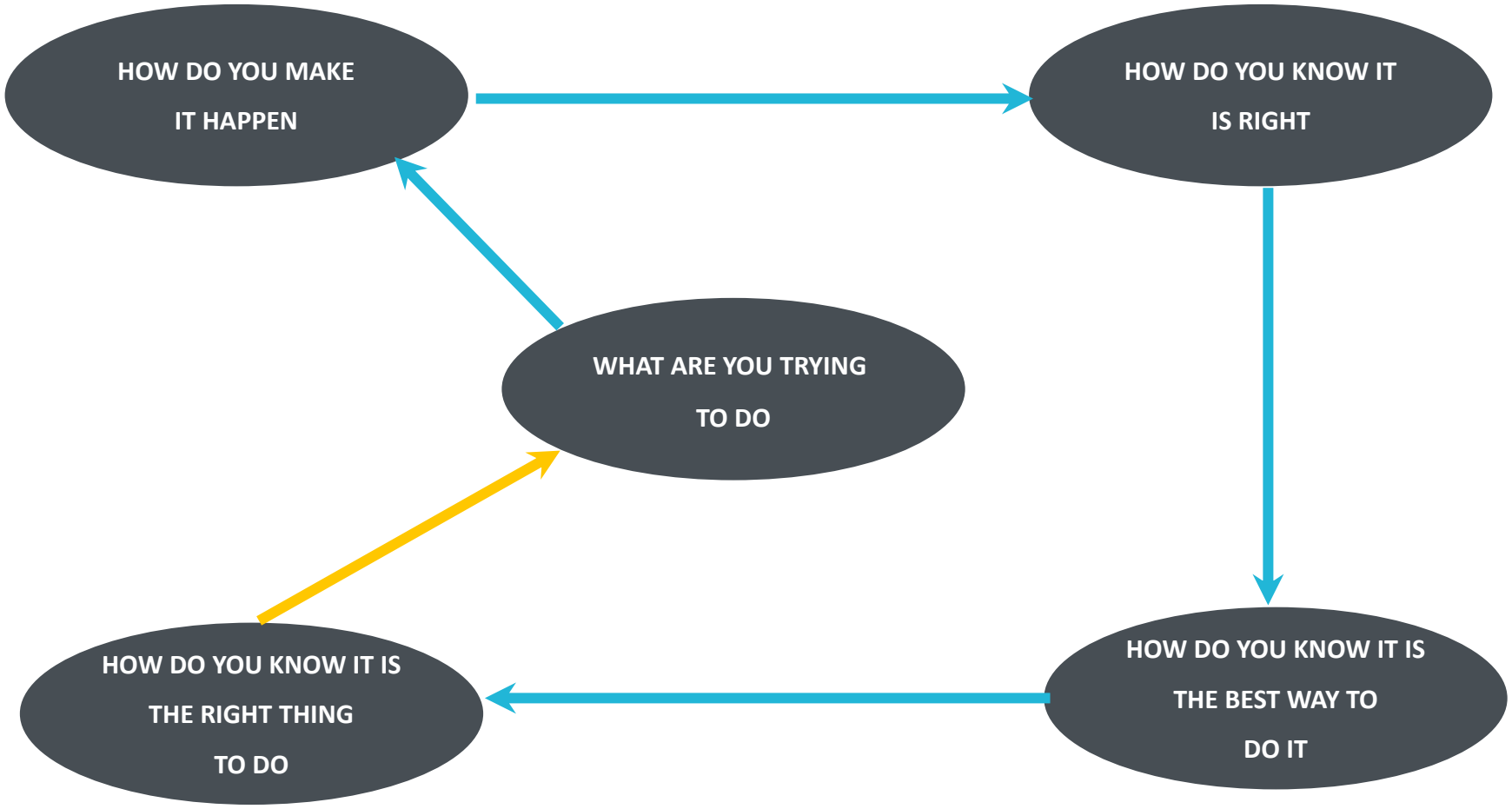
Keep conversation going

Repeat last word or phrase - say something nice

Avoid double questions (2 questions in 1)

Only one answer is likely to result

QUESTION TECHNIQUE



QUESTIONING TECHNIQUES

- Keep conversation going
- Repeat last word or phrase - say something nice
- Avoid double questions (2 questions in 1)
- Only one answer is likely to result

OBJECTIVE EVIDENCE

Try to establish:

- That authorised documents are in use
- Records exist and are managed
- That good housekeeping is practised
- That facilities are adequate
- That supervision is adequate

OBJECTIVE EVIDENCE

That orderly records are kept

That staff are adequately trained

Well prepared checklists will assist when answering these questions

FINDING THE ROOT CAUSE

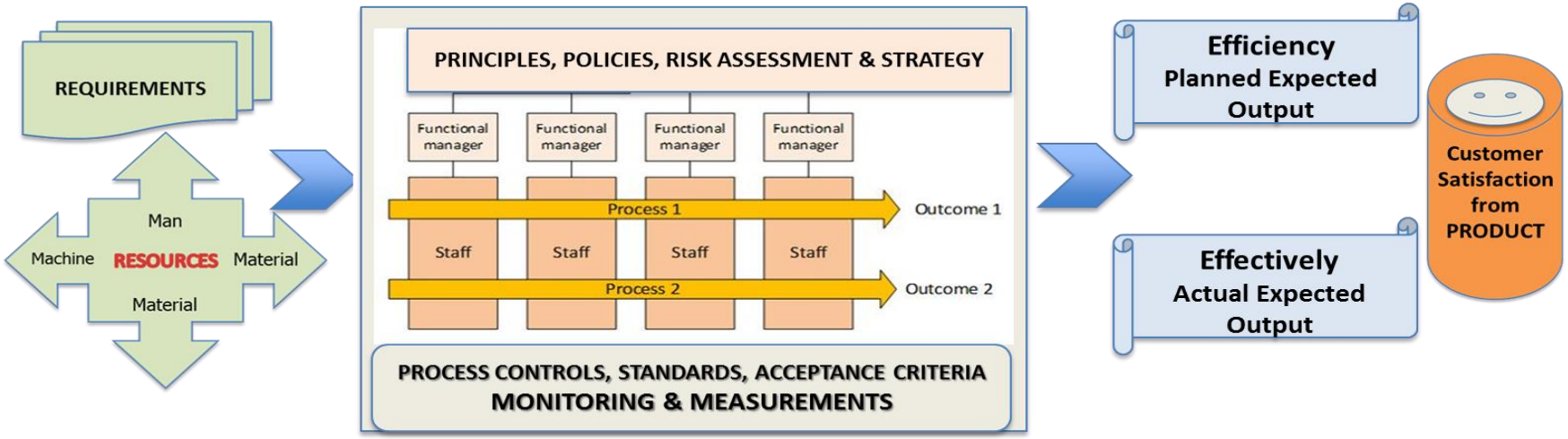
Investigate Nonconformity

Establishing the root cause

Recording the results

EVIDENCES IN AUDITS – SAMPLES IN AUDIT TRIAL

Process > Set of interacting activities which transforms inputs and outputs



Forward Trial (Inputs – Process – Outputs)

Backward Trial (Outputs – Process – Inputs)

AUDIT TECHNIQUES

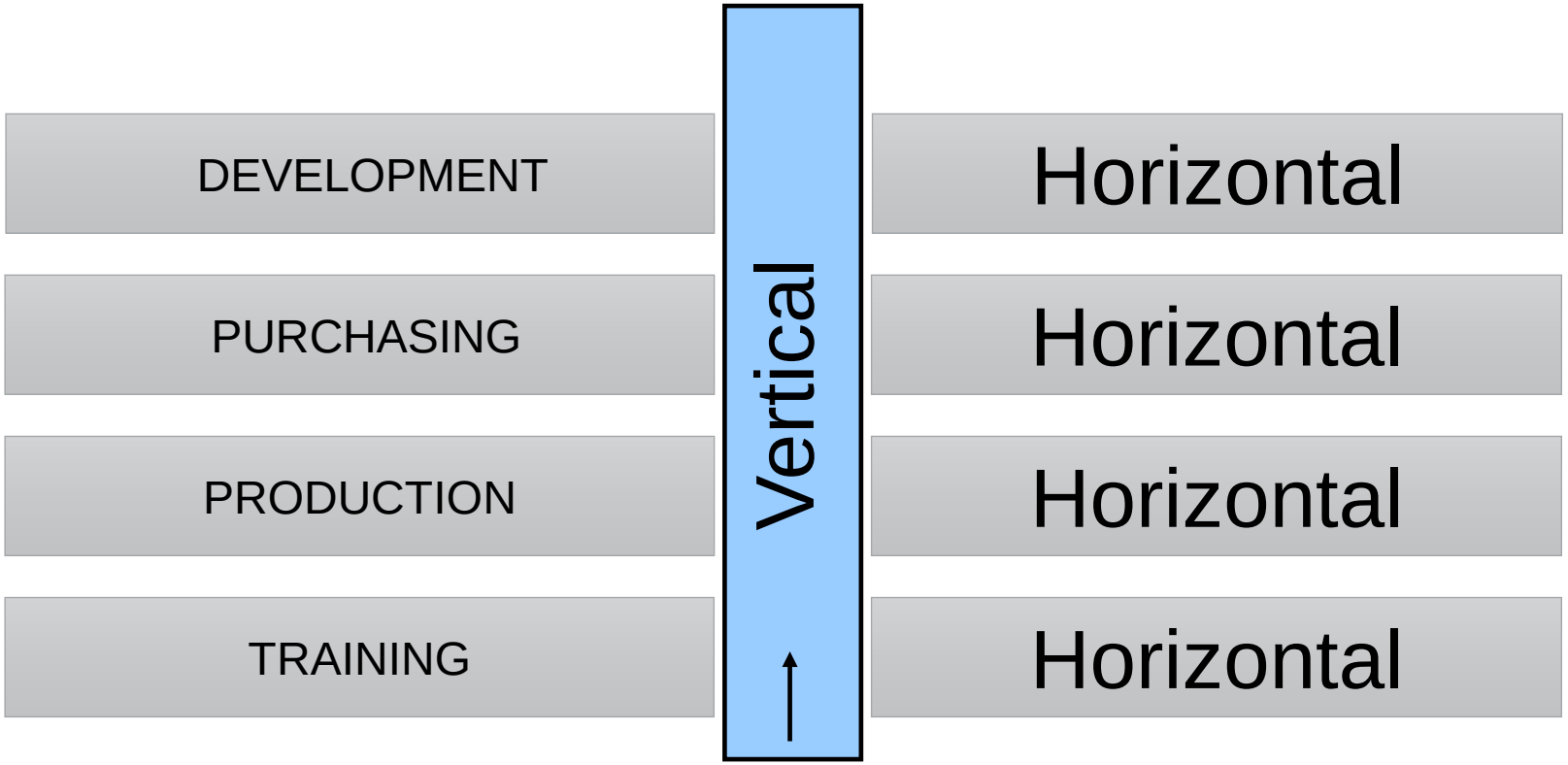
1. Horizontal Audit

When conducting Audits it is common practice to plan to cover department by department with the scope of the Audit. Such Audits are effective at examining each department against their own quality procedure for which they have direct responsibility. However, such Audits fail to address departmental interface.

2. Vertical or Project

Such Audits follow a project trail through a company, e.g. through design, purchasing, production, test and dispatch. But in completing the trail will ensure that departmental interfaces are functioning adequately.

AUDIT TECHNIQUES



The processes cross through departments and functions, this is why the vertical audit tests the interdependency between process

Audits follow a department cross points

AUDIT TECHNIQUES

Forward Trace - An audit which follows the natural flow of a product or service process

Backward Trace - An audit which traces records back through the system

CONDUCTING THE AUDIT

- The auditors audit the area assigned to them in the audit plan.
- Sample the system.
- Collect objective evidence of system effectiveness.
- Compare findings from checklist with requirements.
- Decide compliance or noncompliance.
- Audit team daily meeting [or more frequently].

CONDUCTING THE AUDIT

- Decide on system effectiveness.
- Agree and categorise non-conformities.
- Hold a meeting daily with auditee’s representatives, and at the end of the audit, prior to the closing meeting.
- Prepare summary report with conclusions and indicate recommendations.

THE AUDIT

Remember the auditor is attempting to prove the system compliance

- ESTABLISHING THE FACTS
- AND FINDING THE PROOF
- THE AIM IS NOT TO SET OUT TO FAIL THE SYSTEM!

OBSERVATIONS

Observations may be obtained through any of the following methods:

- Seeking objective evidence that the
- system is functioning as prescribed.

- Samples taken of the system will allow the
- auditor to obtain the required evidence.

OBSERVATIONS

Always establish objective evidence when an apparent nonconformity is found, remember the occurrence discovered may be the effect and not the cause.

Where processes are involved the audit may examine the process controls and records to establish conformance with the specification.

Both positive and negative observations are recorded.

intertek

Total Quality. Assured.

SECTION 16
RAISING NCRS

PURPOSE OF THIS SESSION: TO ESTABLISH THE GROUND RULES FOR WRITING AND AGREEING NCR'S. TO UNDERSTAND THE POSSIBLE DIFFERENCES BETWEEN NCR'S RAISED DURING 1ST, 2ND AND 3RD PARTY AUDITS. TO CLARIFY CATEGORIZATION/GRADING OF NON-CONFORMANCE REPORTS. TO EXAMINE WHEN OBSERVATIONS SHOULD USED.

IDENTIFYING AND RECORDING AUDIT FINDINGS

Audit findings summarizing conformity and detailing nonconformity shall be identified, classified recorded to enable an informed certification decision to be made or the certification to be maintained.

Opportunities for improvement may be identified and recorded. Audit findings, however, which are nonconformities, shall not be recorded as opportunities for improvement

AUDIT FINDINGS ISO 19011

When determining audit findings, the following should be considered

a) follow-up of previous audit records and conclusions;

b) requirements of the audit client;

c) accuracy, sufficiency and appropriateness of objective evidence to support audit findings;

d) extent to which planned audit activities are realized and planned results achieved;

e) findings exceeding normal practice, or opportunities for improvement;

f) sample size;

g) categorization (if any) of the audit findings

RECORDING CONFORMITIES

For records of conformity, the following should be considered:

a) description of or reference to audit criteria against which conformity is shown;

b) audit evidence to support conformity and effectiveness, if applicable;

c) declaration of conformity, if applicable.

RECORDING NONCONFORMITIES

For records of nonconformity, the following should be considered:

a) description of or reference to audit criteria;

b) audit evidence;

c) declaration of nonconformity;

d) related audit findings, if applicable

NONCONFORMITY REPORTING

What is the Problem?

describe clearly, concisely and factually

Why is it a noncompliance?

i.e. against what requirement

Where did it occur?

i.e. which department or activity

Who? – avoid apportioning blame

(i.e. naming individuals)

NONCONFORMITY REPORT

- Used to report nonconformity audit findings
- Must be factual
- Must be understandable and traceable
- Raise formal notification of any issues at the time of finding
- Allow the auditee to implement corrective action prior to the closing meeting
- The auditee is requested to sign signifying an understanding and acceptance of the non-compliance

WORDING OF NCR'S

It is important when preparing NCR's to take care and ensure it is justified.

Failure to achieve clear factual information will invite challenge of the findings at the closing meeting.

This will be particularly important in areas where the emphasis is placed on the following

- Management Commitment
- Competence
- Communication
- Continual improvement

OBSERVATIONS

Notes made by an auditor during assessment may lead to non-compliances being raised or to provide information for the audit report

Notes provide Objective Evidence back up

CATEGORISING NON-CONFORMITIES

Major

A single major system, product, or service nonconformity

- A lack of documented information needed to satisfy an agreed requirement
- Non-implementation of documented information and arrangements
- A series of minor non-conformities in a particular area or activity which collectively have an adverse effect on the system

Minor

There is a defined system, documented information and arrangements which satisfy agreed requirements against which the organisation being assessed can demonstrate an acceptable level on implementation overall, but there are minor discrepancies or lapses in discipline.

REVIEWING CORRECTIVE ACTIONS

- To ensure actions corrective actions requested are being implemented by auditee.
- The agreed timescales are achieved.
- Corrective actions are effective.

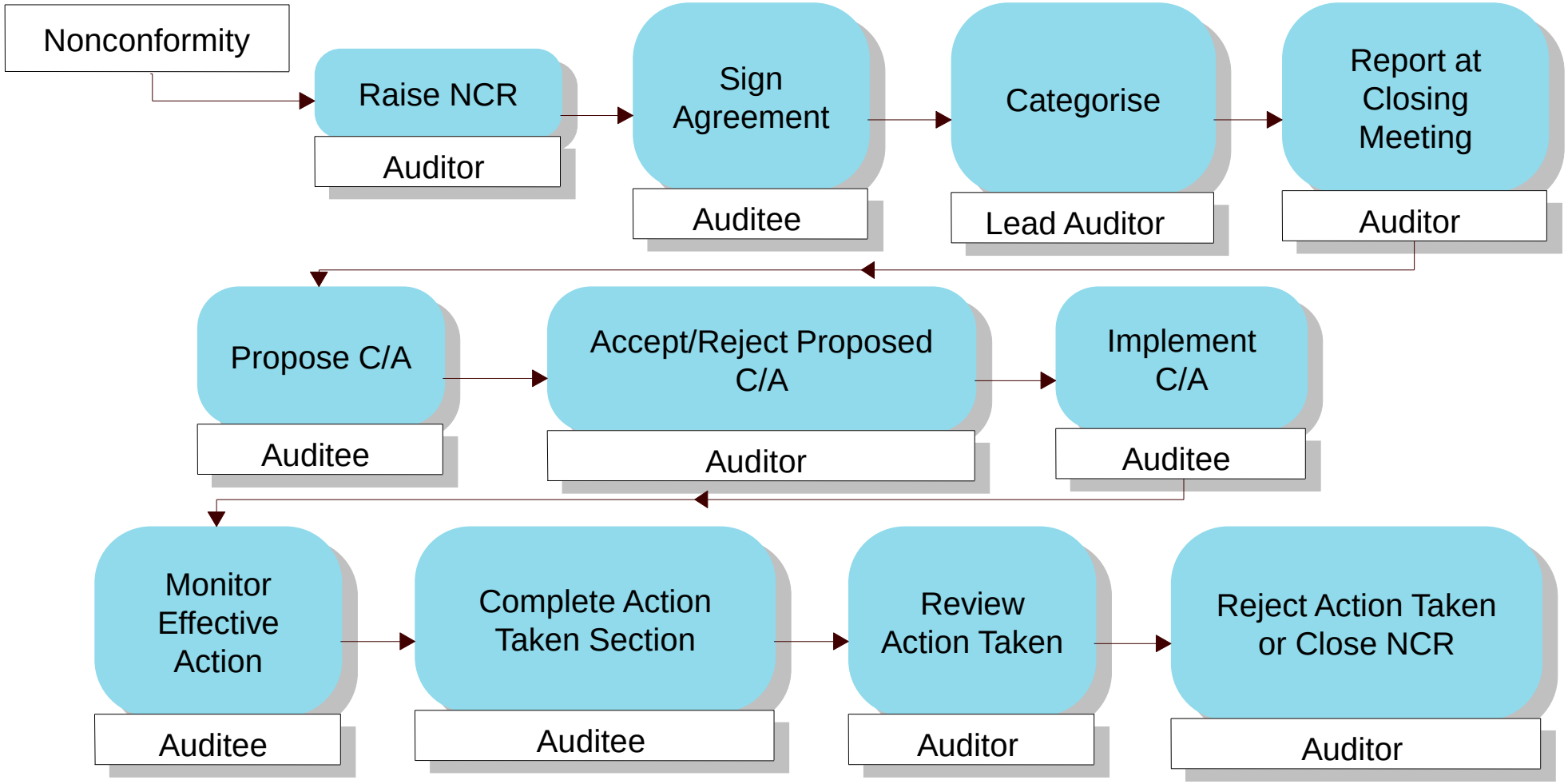
REVIEWING CORRECTIVE ACTIONS

Corrective Action implementation can be verified off-site based on documentary evidence provided.

Follow-up visits may be as necessary to verify actions have been take and were effective.

Non-conformities should be closed out at each visit or further corrective actions agreed.

CORRECTIVE ACTION RESPONSIBILITIES



intertek

Total Quality. Assured.

SECTION 17 CONDUCTING AUDITS: AUDIT REPORTING AND CLOSING MEETING

PURPOSE OF THIS SESSION: TO DEVELOP AUDITING SKILLS. TO BE ABLE TO LIST AND PRESENT CLOSING MEETING AGENDA POINTS. TO ABLE TO LIST AND COMPILE THE CONTENTS OF AN ASSESSMENT REPORT.

AUDIT REPORTING

Content:

a) identification of the certification body;

b) the name and address of the client and the client’s representative;

c) the type of audit (e.g. initial, surveillance or recertification audit or special audits);

d) the audit criteria;

e) the audit objectives;

f) the audit scope

g) any deviation from the audit plan and their reasons

h) any significant issues impacting on the audit programme

AUDIT REPORTING

i) identification of the audit team leader, audit team members and any accompanying persons;

j) the dates and places where the audit activities were conducted

k) audit findings

l) significant changes

m) any unresolved issues, if identified

n) where applicable, whether the audit is combined, joint or integrated

o) statement that auditing is based on a sampling process of the available information;

p) recommendation from the audit team

q) use of the certification documents and marks, if applicable

r) verification of effectiveness of taken corrective actions regarding previously identified nonconformities, if applicable

AUDIT REPORTING CONCLUSIONS

Audit report shall contain the following conclusions:

- a statement on the conformity and the effectiveness of the management system together with a summary of the evidence relating to

  - the capability of the management system to meet applicable requirements and expected outcomes

  - the internal audit and management review process

- a conclusion on the appropriateness of the certification scope

- confirmation that the audit objectives have been fulfilled

AUDIT FILE

- Audit plan
- Audit report
- Open/closing meeting attendance list
- Copies of non-conformity reports and objective evidence provided
- Assignment of the audit teams
- Confidentiality statements of the audit team

PURPOSE OF CLOSING MEETING

Advise auditee of findings and conclusions reached based on the audit findings

Advise on the recommendation to be made

- ACCEPTABLE
- UNACCEPTABLE

CLOSING MEETING

The closing meeting shall also include the following elements:

- advising the client that the audit evidence obtained was based on a sample of the information; thereby introducing an element of uncertainty
- the method and timeframe of reporting, including any grading of audit findings
- the certification body’s process for handling nonconformities including any consequences relating
- to the status of the client’s certification
- the timeframe for the client to present a plan for correction and corrective action for any
- nonconformities identified during the audit
- the certification body’s post audit activities
- information about the complaint and appeal handling processes
- Opportunities for questions

Thank you!

intertek

Total Quality. Assured.